ISGA
Institut supérieur
d'ingénierie et des affaires

PROJET DE FIN D'ANNÉE — PFA

Ingénierie et Sécurité des Systèmes d'Information

RAPPORT TECHNIQUE FINAL

Mise en place d'un Mini-SOC avec collecte de logs FortiGate, Linux et Windows

SIEM Wazuh 4.x — FortiGate (FortiOS 8.0) — Ubuntu 22.04 — Windows Server 2022 — Kali Linux

Encadré par :Mr. AIT IBOUREK LAHCEN

Réalisé par (étudiant·e·s) : Mr. Rachid Bouselama
Mr. Younes Mezzane
Mr. Abderrahim Goubraim
Mr. Oualid Bouzarhoun
Mr. Abdelhakim Fatnassi

Année universitaire 2025 — 2026

بِسْمِ اللَّـهِ الرَّحْمَـٰنِ الرَّحِيمِ

Dédicace

C'est avec une profonde gratitude et un grand respect que nous dédions ce travail de fin d'année, concrétisant notre parcours en Ingénierie et Sécurité des Systèmes d'Information.

À notre encadrant, **Mr. AIT IBOUREK LAHCEN**, pour ses précieux conseils, son orientation constante, ainsi que pour nous avoir proposé ce sujet particulièrement captivant, enrichissant et au cœur des enjeux actuels de la cybersécurité. À l'ensemble du corps professoral de notre filière pour la qualité de l'enseignement dispensé et leur engagement à former des ingénieurs qualifiés.

À nos collègues et ami(e)s, pour leur esprit d'entraide, leur soutien moral et les moments partagés durant cette année académique 2025 — 2026.
Mr. Rachid Bouselama
Mr. Younes Mezzane
Mr. Abderrahim Goubraim
Mr. Oualid Bouzarhoun
Mr. Abdelhakim Fatnassi

Sommaire

Après toute modification, clic droit sur le sommaire puis « Mettre à jour les champs » pour actualiser les pages.

Sommaire 3
1. Introduction, architecture et stack technique 6
1.1 Contexte, problématique et objectifs 6
1.1.1 Contexte général 6
1.1.2 Problématique 6
1.1.3 Objectifs du projet 6
1.1.4 Périmètre supervisé 7
1.2 Architecture générale et topologie réseau 7
1.2.1 Vue d'ensemble : deux zones de sécurité 7
1.2.2 Réseaux virtuels VMware 2
1.2.3 Adressage IP et rôles des machines 2
1.2.4 Flux de logs vers le SIEM 3
1.3 Stack technique et dimensionnement 3
1.3.1 Pourquoi Wazuh ? 3
1.3.2 Composants déployés 4
1.3.3 Dimensionnement des machines virtuelles 4
2. Collecte, normalisation et ingénierie de détection 5
2.1 Ingestion multi-sources 5
2.1.1 Source 1 — FortiGate : envoi Syslog 5
2.1.2 Source 2 — Ubuntu Client : agent Wazuh, rsyslog et auditd 6
2.1.3 Source 3 — Windows Server 2022 : Sysmon, WEF et agent Wazuh 7
2.2 Normalisation et validation des logs 8
2.2.1 Normalisation : un même format pour toutes les sources 8
2.2.2 Validation de la collecte 8
2.2.3 Chiffrement des communications (ENF-04) 9
2.3 Ruleset de détection personnalisé (R01 à R05) 9
2.3.1 Principe de fonctionnement des règles Wazuh 9
2.3.2 Tableau de synthèse du ruleset 10
2.3.3 R01 — Force brute SSH (règle 100005) 10
2.3.4 R02 — Scan de ports (règles 100010 et 100011) 10
2.3.5 R03 — Élévation de privilèges via sudo (règle 100002) 11
2.3.6 R04 — Exfiltration de données (règle 100004) 11
2.3.7 R05 — Création de compte non autorisée (règle 100003) 11
2.3.8 Règles complémentaires : dump LSASS et exploit Shellshock 12
3. Alerting, tableaux de bord et simulations d'attaques 13
3.1 Moteur d'alerte en temps réel 13
3.1.1 Niveaux de sévérité (exigence EF-09) 13

3.1.2 Anti-flood (exigence EF-10) 13
3.2 Tableaux de bord de supervision 14
3.2.1 Vue globale — Mini-SOC Global Overview 14
3.2.2 Dashboard FortiGate 14
3.2.3 Dashboard Ubuntu-Client 15
3.2.4 Dashboard Windows-Server 15
3.3 Simulations d'attaques et synthèses d'incidents (ISO 27035) 16
3.3.1 Scénario 1 — Force brute SSH (règle R01) 16
3.3.2 Scénario 2 — Reconnaissance réseau, scan Nmap (règle R02) 16
3.3.3 Scénario 3 — Dump mémoire LSASS sur Windows (règle 100090) 17
3.3.4 Scénario 3 bis — Élévation de privilèges via sudo (règle R03) 17
3.3.5 Scénario 4 — Exfiltration de données (règle R04) 18
3.3.6 Scénario 5 — Création de compte non autorisée (règle R05) 18
3.3.7 Scénario 6 — Exploitation web Shellshock, CVE-2014-6271 (règle 100012) 19
3.3.8 Tableau récapitulatif des simulations 19
4. Gouvernance, tests, difficultés et conclusion 20
4.1 Gouvernance opérationnelle et artefacts de réponse 20
4.1.1 Organisation de l'équipe SOC (mini RACI) 20
4.1.2 Méthode de réponse ISO/IEC 27035 20
4.1.3 Artefacts produits 20
4.2 Tests non fonctionnels et matrice de conformité 21
4.2.1 Performance : événements par seconde (ENF-01 et ENF-02) 21
4.2.2 Synchronisation horaire NTP (ENF-06) 21
4.2.3 Matrice de conformité au cahier des charges 22
4.3 Obstacles techniques et dépannage 23
4.3.1 Obstacle 1 — La NAT du FortiGate masque l'attaquant 23
4.3.2 Obstacle 2 — Limites de la licence d'évaluation FortiGate 23
4.3.3 Obstacle 3 — Synchronisation NTP et réglage des seuils de détection 23
4.4 Conclusion et feuille de route 24
4.4.1 Bilan du projet 24
4.4.2 Limites actuelles (évaluation honnête) 24
4.4.3 Feuille de route 24

Liste des Figures

- **Figure 1.1 :** Schéma de l'architecture réseau du Mini-SOC (FortiGate, Wazuh SIEM, Ubuntu, Windows Server, Kali Linux) (Section 1.2.1)
- **Figure 1.2 :** Configuration des réseaux virtuels VMware (VMnet1 Host-only 192.168.50.0/24 et VMnet8 NAT 10.10.0.0/16) (Section 1.2.2)
- **Figure 1.3 :** Mire de connexion du Wazuh Dashboard (HTTPS) — accès protégé par authentification (exigence ENF-05) (Section 1.3.2)
- **Figure 1.4 :** Paramètres réels des cinq machines virtuelles dans VMware Workstation (mémoire, processeurs, disques, cartes réseau) (Section 1.3.3)
- **Figure 2.1 :** Console FortiGate — tableau de bord, interfaces (port1 WAN 10.10.10.10, port2 LAN 192.168.50.1), politique LAN-to-WAN avec NAT, et activation de la journalisation Syslog vers 192.168.50.10 (Section 2.1.1)
- **Figure 2.2 :** Agent Wazuh actif (running) sur l'Ubuntu Client — version 4.14.7, service activé au démarrage (Section 2.1.2)
- **Figure 2.3 :** Vérification du service rsyslog — état « active » sur l'Ubuntu Client (Section 2.1.2)
- **Figure 2.4 :** Extrait de ossec.conf de l'agent Linux — lecture de /var/log/audit/audit.log (format audit), /var/log/syslog, /var/log/kern.log, /var/log/dpkg.log et des journaux de réponse active (Section 2.1.2)
- **Figure 2.5 :** Fichier de configuration Sysmon SwiftOnSecurity (version 74) — traçage d'événements à haute valeur, compatible Sysmon 13+ (Section 2.1.3)
- **Figure 2.6 :** Service Sysmon64 en cours d'exécution sur Windows Server 2022 (Get-Service Sysmon*) (Section 2.1.3)
- **Figure 2.7 :** Service Wecsvc (Windows Event Collector) actif sur Windows Server 2022 (Section 2.1.3)
- **Figure 2.8 :** Console Wazuh — agents connectés (Ubuntu-Client 192.168.50.30 et Windows Server 192.168.50.20 actifs) et événements collectés depuis les trois sources (FortiGate, sshd/PAM, Sysmon) (Section 2.2.2)
- **Figure 2.9 :** Test OpenSSL agent → serveur — session TLSv1.2, chiffrement ECDHE-RSA-AES256-GCM-SHA384 (Section 2.2.3)
- **Figure 3.1 :** Configuration des alertes dans ossec.conf — intégration Slack (webhook, liste des règles) et alertes e-mail (niveau ≥ 10) (Section 3.1)
- **Figure 3.2 :** Liste des quatre tableaux de bord — Mini-SOC Global Overview, Fortigate, Ubuntu-Client et Windows-Server (Section 3.2)
- **Figure 3.3 :** Dashboard « Mini-SOC Global Overview » — timeline, alertes par sévérité, statut des agents (actifs) et top 10 des IP sources (192.168.50.1, 10.10.10.20, 192.168.50.100) (Section 3.2.1)
- **Figure 3.4 :** Dashboard FortiGate — alertes de sévérité 10, top IP attaquante (10.10.10.20) et dernier événement du pare-feu (Section 3.2.2)
- **Figure 3.5 :** Dashboard Ubuntu-Client — répartition des sévérités, timeline et statut de l'agent 192.168.50.30 (Section 3.2.3)
- **Figure 3.6 :** Dashboard Windows-Server — alertes de niveaux 12 et 15, statut de l'agent actif (Section 3.2.4)
- **Figure 3.7 :** Scénario 1 — règle 100005, document JSON de l'alerte (agent 001, srcip 192.168.50.1, port 40004) et notification Slack (niveau 10) (Section 3.3.1)
- **Figure 3.8 :** Scénario 2 — règles 100010/100011, paquet iptables SYN (SPT=44854, DPT=21) et notification Slack (niveau 10) (Section 3.3.2)
- **Figure 3.9 :** Scénario 3 — règle 100090 (niveau 12), document JSON Sysmon (ligne de commande, processus parent PowerShell, hashes) et e-mail d'alerte critique (Section 3.3.3)
- **Figure 3.10 :** Scénario 3 bis — règle 100002, document JSON (sudo, srcuser soc, dstuser root) et notification Slack (niveau 10) (Section 3.3.4)
- **Figure 3.11 :** Scénario 4 — règle 100004, document JSON (GET /confidential_database.sql, srcip 192.168.50.1) et notification Slack (niveau 10) (Section 3.3.5)
- **Figure 3.12 :** Scénario 5 — règle 100003, document JSON (new user malicious_user, UID=1001) et notification Slack (niveau 10) (Section 3.3.6)
- **Figure 3.13 :** Scénario 6 — règle 100012 et règle 31168 (niveau 15), document JSON (User-Agent malveillant) et notification Slack (Section 3.3.7)
- **Figure 4.1 :** Dépôt Git « mini-soc-config » — commit initial conforme au CDC (README, agent/ossec-agent.conf, manager/ossec.conf, rules/local_rules.xml) (Section 4.1.3)
- **Figure 4.2 :** Compteurs internes de wazuh-analysisd — 14 161 événements traités, files d'attente à 16 384 (Section 4.2.1)
- **Figure 4.3 :** Vérification NTP — timedatectl sur Ubuntu et Wazuh (service NTP actif), w32tm sur Windows (source horloge locale) (Section 4.2.2)

1. Introduction, architecture et stack technique

1.1 Contexte, problématique et objectifs

1.1.1 Contexte général

Face à la multiplication des cybermenaces (rançongiciels, attaques ciblées, vols d'identifiants), chaque organisation a besoin de surveiller son système d'information en continu. L'outil de référence pour cela s'appelle un SOC (Security Operations Center) : une équipe, appuyée par des logiciels, qui surveille la sécurité 24h/24 et réagit aux incidents.

Au cœur d'un SOC se trouve un SIEM (Security Information and Event Management). C'est un logiciel qui collecte les journaux (logs) de toutes les machines, les analyse en temps réel et déclenche des alertes quand quelque chose d'anormal se produit. Dans ce projet, notre SIEM est Wazuh, une solution open-source complète et largement utilisée en entreprise.

Ce projet de fin d'année consiste à construire un Mini-SOC complet dans un environnement virtualisé VMware, avec des outils professionnels, et à le tester avec de vraies attaques simulées.

1.1.2 Problématique

Le cahier des charges pose la question suivante : comment concevoir et déployer un mini-SOC capable de centraliser, corréler et analyser en temps réel les événements de sécurité issus d'une infrastructure hétérogène (FortiGate, serveur Linux, Windows Server), et de produire des alertes et des rapports d'incidents conformes aux bonnes pratiques de la norme ISO 27035 ?

La norme ISO/IEC 27035 est le référentiel international de gestion des incidents de sécurité. Elle décrit les étapes à suivre quand un incident arrive : le détecter, l'évaluer, le contenir, l'éradiquer, puis en tirer des leçons.

1.1.3 Objectifs du projet

L'objectif général est de déployer un mini-SOC fonctionnel, capable de collecter, normaliser, corréler et alerter sur des événements de sécurité multi-sources. Les objectifs spécifiques fixés par le cahier des charges sont :

- mettre en place une architecture de collecte centralisée des logs (FortiGate, Linux, Windows) ;
- déployer et configurer la solution SIEM Wazuh ;
- créer des règles de détection personnalisées pour au moins 5 types d'attaques (R01 à R05) ;
- implémenter un système d'alertes automatiques (e-mail et Slack) ;
- simuler des scénarios d'attaques réels et les détecter via le SIEM ;
- rédiger des rapports d'incidents conformes à la structure ISO 27035 ;
- construire un tableau de bord de supervision en temps réel ;
- documenter l'ensemble de l'infrastructure et des procédures.

1.1.4 Périmètre supervisé

L'infrastructure supervisée comprend : un pare-feu FortiGate (VM FortiOS) qui génère des logs réseau et de sécurité, un poste Ubuntu 22.04 LTS surveillé avec auditd et Syslog, un serveur Windows Server 2022 surveillé avec Windows Event Log et Sysmon, et un poste Kali Linux qui joue le rôle de l'attaquant pour les scénarios de test. Toutes les attaques sont réalisées uniquement dans le réseau virtuel isolé, comme l'exige le cahier des charges.

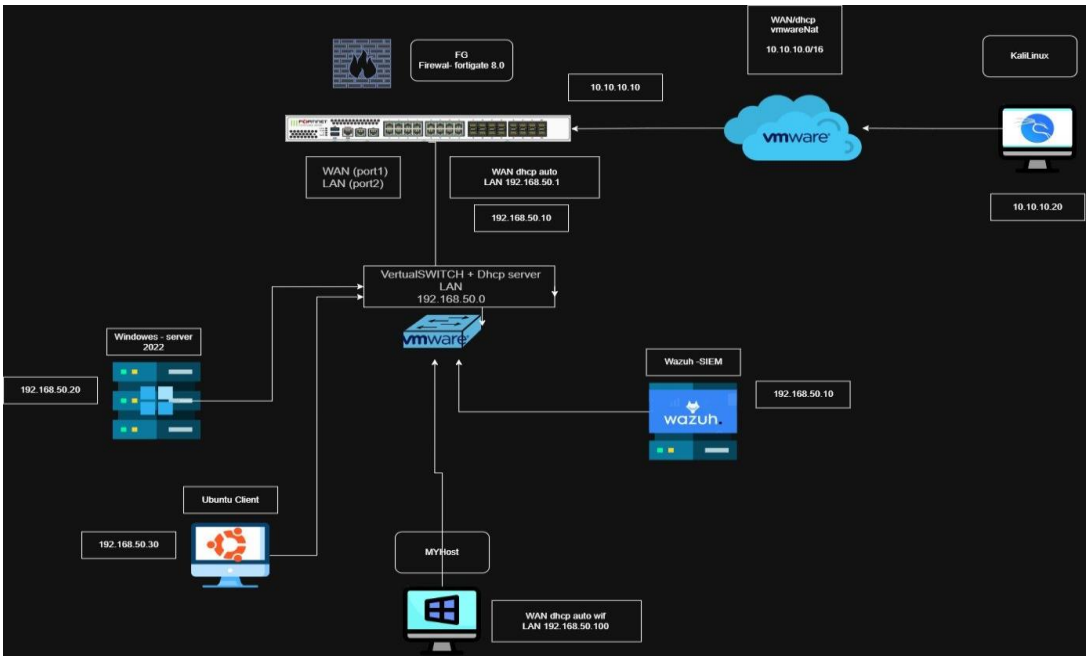
1.2 Architecture générale et topologie réseau

1.2.1 Vue d'ensemble : deux zones de sécurité

Le laboratoire est organisé en deux zones, séparées par le pare-feu FortiGate. Cette séparation imite une vraie entreprise : une zone externe (le « WAN », côté Internet) et une zone interne (le « LAN », côté serveurs).

Zone	Réseau VMware	Contenu
WAN (externe)	VMnet8 — NAT — 10.10.0.0/16	Poste attaquant Kali Linux (10.10.10.20) et interface WAN du FortiGate (10.10.10.10)
LAN (interne)	VMnet1 — Host-only — 192.168.50.0/24	Wazuh SIEM (192.168.50.10), Windows Server 2022 (192.168.50.20), Ubuntu Client (192.168.50.30), machine hôte d'administration (192.168.50.100)

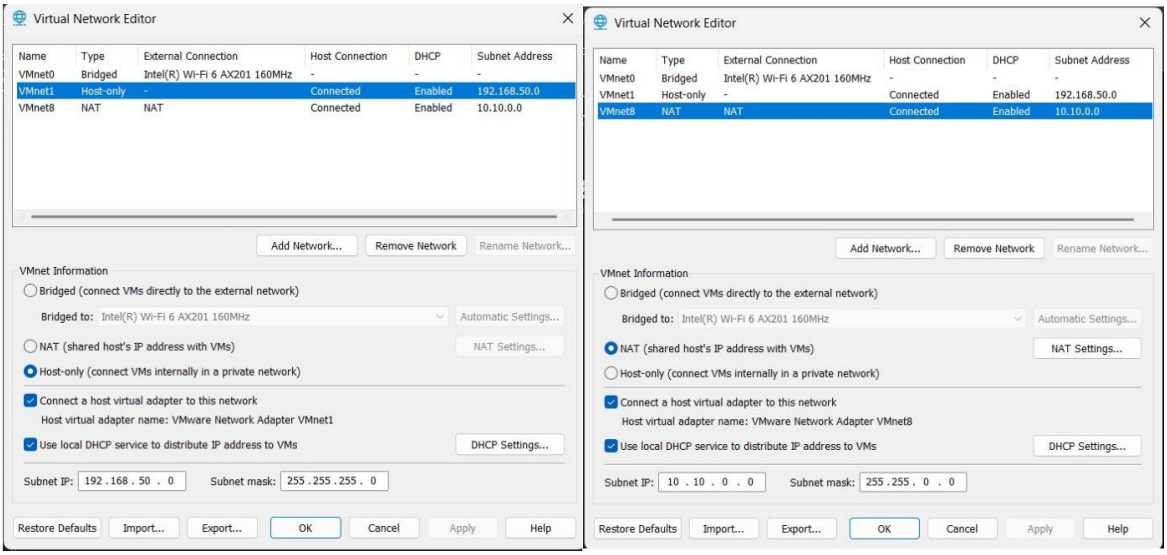
Le pare-feu FortiGate possède deux interfaces : port1 côté WAN (10.10.10.10) et port2 côté LAN (192.168.50.1). Il fait le pont entre les deux zones, filtre le trafic et journalise tout ce qui passe. Le Kali Linux, placé uniquement dans la zone WAN, ne peut pas atteindre les machines du LAN sans traverser le pare-feu : cela respecte la contrainte d'isolement du cahier des charges.



Capture d'écran 1.1 : Schéma de l'architecture réseau du Mini-SOC (FortiGate, Wazuh SIEM, Ubuntu, Windows Server, Kali Linux).

1.2.2 Réseaux virtuels VMware

Toute l'infrastructure repose sur VMware Workstation. Deux réseaux virtuels jouent le rôle de commutateurs : VMnet1 (Host-only, sous-réseau 192.168.50.0/24) pour le LAN, et VMnet8 (NAT, sous-réseau 10.10.0.0/16) pour le WAN avec accès Internet. Le service DHCP de VMware attribue les adresses, et des adresses fixes sont utilisées pour les serveurs.



Capture d'écran 1.2 : Configuration des réseaux virtuels VMware (VMnet1 Host-only 192.168.50.0/24 et VMnet8 NAT 10.10.0.0/16).

1.2.3 Adressage IP et rôles des machines

Machine	Adresse IP	Rôle dans le SOC
FortiGate (FortiOS 8.0)	10.10.10.10 (WAN) / 192.168.50.1 (LAN)	Pare-feu : filtre le trafic et envoie ses logs en Syslog
Wazuh SIEM	192.168.50.10	Collecte, corrélation, détection, alertes et tableaux de bord
Windows Server 2022	192.168.50.20	Serveur supervisé (Event Log, Sysmon, agent Wazuh)
Ubuntu Client 22.04	192.168.50.30	Machine supervisée (auditd, rsyslog, agent Wazuh)
Kali Linux	10.10.10.20	Poste attaquant pour les scénarios de test
Machine hôte	192.168.50.100	Administration des consoles web (Wazuh, FortiGate)

1.2.4 Flux de logs vers le SIEM

Quatre flux principaux circulent dans le laboratoire : le trafic d'attaque simulé (Kali vers le LAN via le FortiGate), la sortie Internet en NAT, le Syslog du pare-feu vers Wazuh, et le trafic des agents Wazuh installés sur Ubuntu et Windows.

Flux	Protocole / port	Source	Destination
Syslog du pare-feu	UDP 514	FortiGate 192.168.50.1	Wazuh 192.168.50.10
Agent Wazuh (Linux)	TCP 1514 (chiffré TLS)	Ubuntu 192.168.50.30	Wazuh 192.168.50.10
Agent Wazuh (Windows)	TCP 1514 (chiffré TLS)	Windows 192.168.50.20	Wazuh 192.168.50.10
Trafic d'attaque (isolé)	TCP / UDP variés	Kali 10.10.10.20	Machines du LAN via FortiGate

Remarque importante sur la NAT : le FortiGate pratique la NAT (traduction d'adresses) : il remplace l'adresse réelle de l'attaquant par la sienne quand le trafic entre dans le LAN. C'est pourquoi, dans plusieurs alertes, l'attaquant Kali (10.10.10.20) apparaît sous l'adresse 192.168.50.1. Ce point est essentiel pour l'analyse des incidents (voir section 4.3).

1.3 Stack technique et dimensionnement

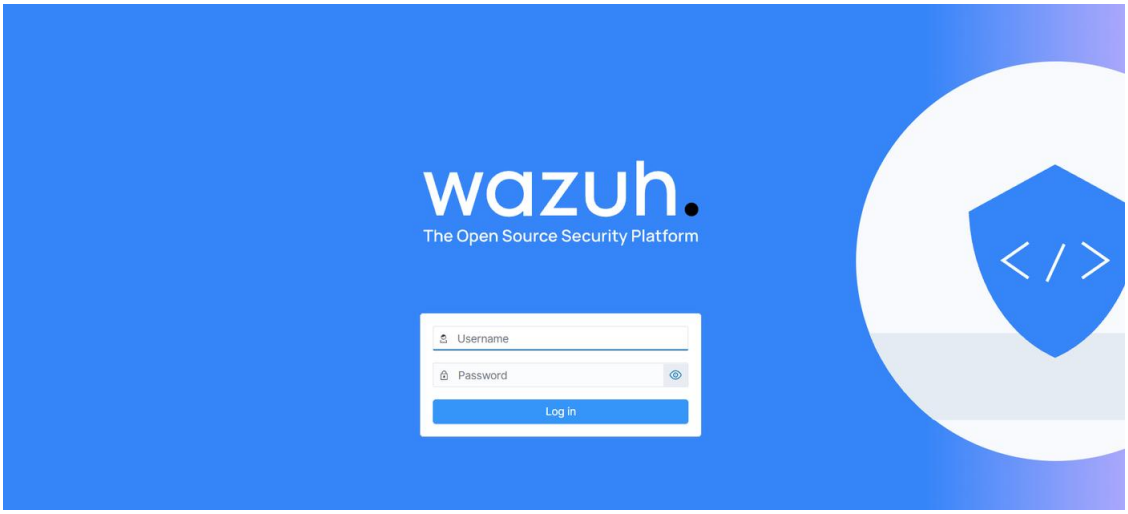
1.3.1 Pourquoi Wazuh ?

Le cahier des charges proposait deux options : Wazuh ou la pile ELK (Elasticsearch, Logstash, Kibana). Nous avons choisi Wazuh 4.x pour plusieurs raisons simples :

- **Tout-en-un :** Wazuh regroupe la collecte (agents), la corrélation (moteur de règles), l'indexation (Wazuh Indexer) et la visualisation (Wazuh Dashboard) dans une seule plateforme cohérente.
- **Détection prête à l'emploi :** il contient des milliers de règles de détection déjà écrites (SSH, sudo, web, Windows...), que l'on peut enrichir avec ses propres règles.
- **Conformité intégrée :** chaque règle peut être reliée au catalogue MITRE ATT&CK, ce qui facilite les rapports d'incidents.
- **Gratuit et open-source :** aucune licence à payer, une documentation officielle très complète.
- **Réponse active :** Wazuh peut réagir tout seul (par exemple bloquer une IP avec le module Active Response), une piste d'évolution pour le projet.

1.3.2 Composants déployés

Composant	Outil / version	Rôle
SIEM	Wazuh 4.14.7 (Manager + Indexer + Dashboard)	Collecte, corrélation, détection, visualisation
Pare-feu	FortiGate-VM — FortiOS v8.0.0 (licence d'évaluation)	Filtrage WAN/LAN, logs Syslog
Source Linux	Agent Wazuh + auditd + rsyslog (Ubuntu 22.04.5 LTS)	Logs système, authentification, audit
Source Windows	Agent Wazuh + Sysmon (config SwiftOnSecurity) + WEF	Event Log, création de processus, réseau
Attaquant	Kali Linux Rolling 2026.2	Scénarios d'attaque simulés
Alerting	E-mail (SMTP Gmail) + webhook Slack	Notifications temps réel
Virtualisation	VMware Workstation Pro	Hébergement des 5 machines virtuelles

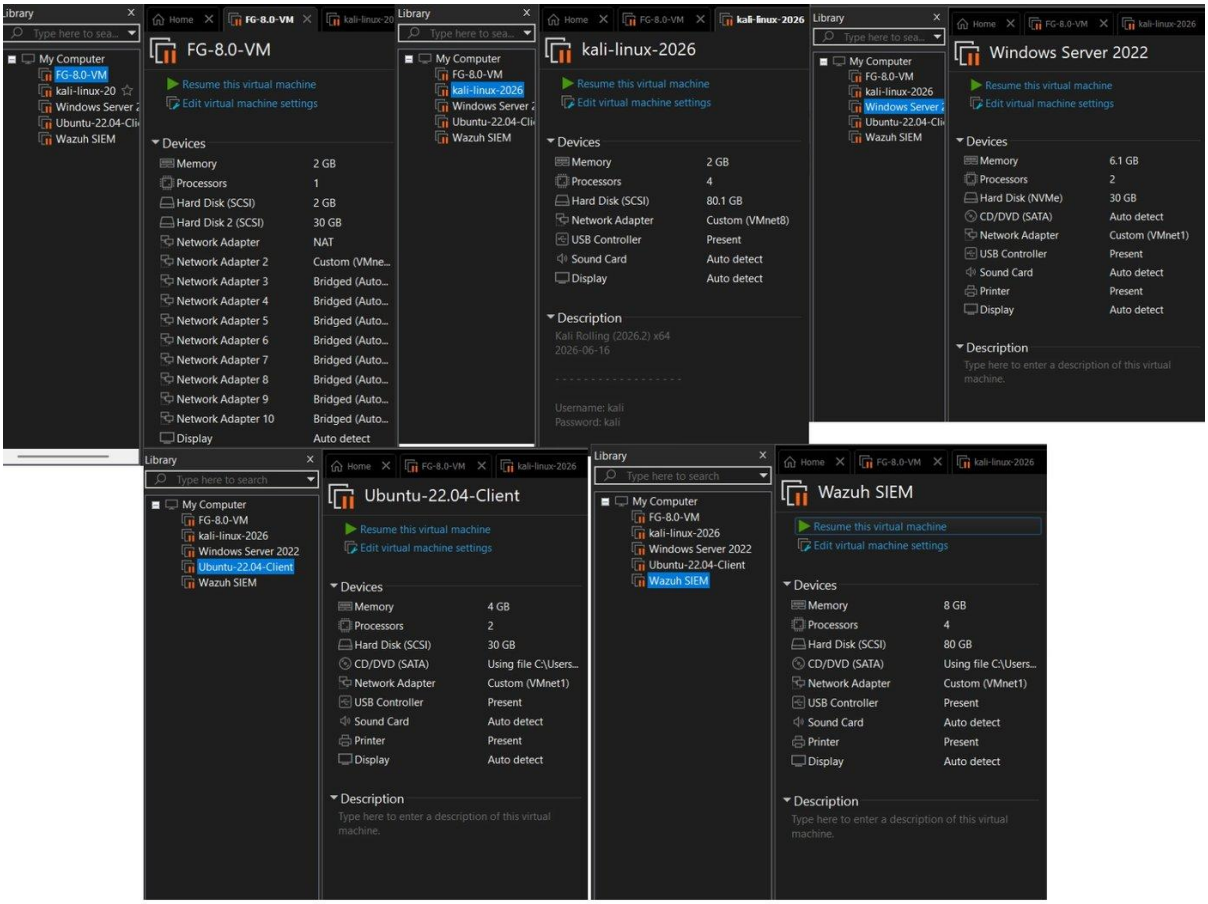


Capture d'écran 1.3 : Mire de connexion du Wazuh Dashboard (HTTPS) — l'accès est protégé par authentification (exigence ENF-05).

1.3.3 Dimensionnement des machines virtuelles

Le tableau ci-dessous compare les ressources réellement allouées aux exigences minimales du cahier des charges (section 9.1). Toutes les exigences sont respectées, sauf le disque du Windows Server (30 Go au lieu de 60 Go), sans impact sur la démonstration.

VM	vCPU	RAM	Disque	Exigence CDC
Wazuh SIEM	4	8 Go	80 Go	4 vCPU / 8 Go / 80 Go : conforme
FortiGate-VM	1	2 Go	2 Go + 30 Go	2 vCPU / 2 Go / 30 Go : conforme (RAM limitée par la licence d'évaluation)
Ubuntu Client	2	4 Go	30 Go	2 vCPU / 2 Go / 40 Go : CPU/RAM conformes
Windows Server 2022	2	6 Go	30 Go	2 vCPU / 4 Go / 60 Go : CPU/RAM conformes
Kali Linux	4	2 Go	80 Go	2 vCPU / 2 Go / 30 Go : conforme



Capture d'écran 1.4 : Paramètres réels des cinq machines virtuelles dans VMware Workstation (mémoire, processeurs, disques, cartes réseau).

2. Collecte, normalisation et ingénierie de détection

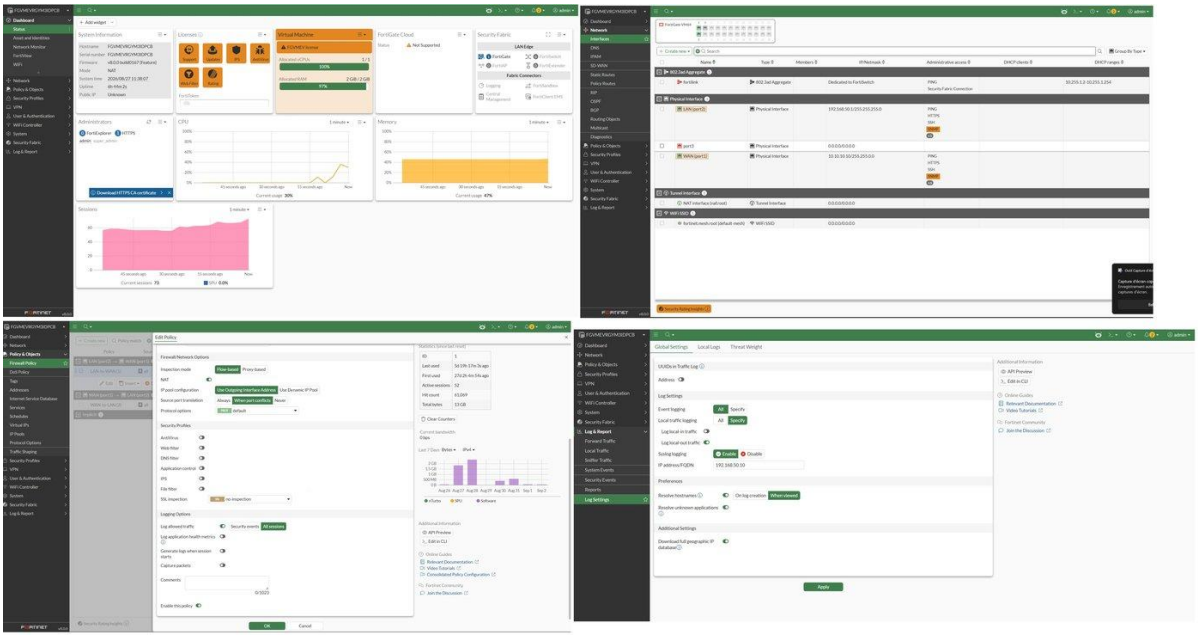
Cette section explique comment les logs des trois sources (FortiGate, Ubuntu, Windows) arrivent jusqu'au SIEM, comment ils sont normalisés, et comment nos règles de détection personnalisées ont été construites.

2.1 Ingestion multi-sources

2.1.1 Source 1 — FortiGate : envoi Syslog

Syslog est le protocole standard pour transporter des journaux entre équipements réseau. Le FortiGate envoie ses événements (trafic, connexions d'administrateur, événements système) au serveur Wazuh en UDP sur le port 514. Sur le pare-feu, la journalisation Syslog est activée et pointe vers 192.168.50.10 ; sur le manager Wazuh, un collecteur Syslog écoute sur ce port.

```
# FortiOS CLI — envoi des logs vers le SIEM
config log syslogd setting
  set status enable
  set server "192.168.50.10"
  set mode udp
  set port 514
end
```

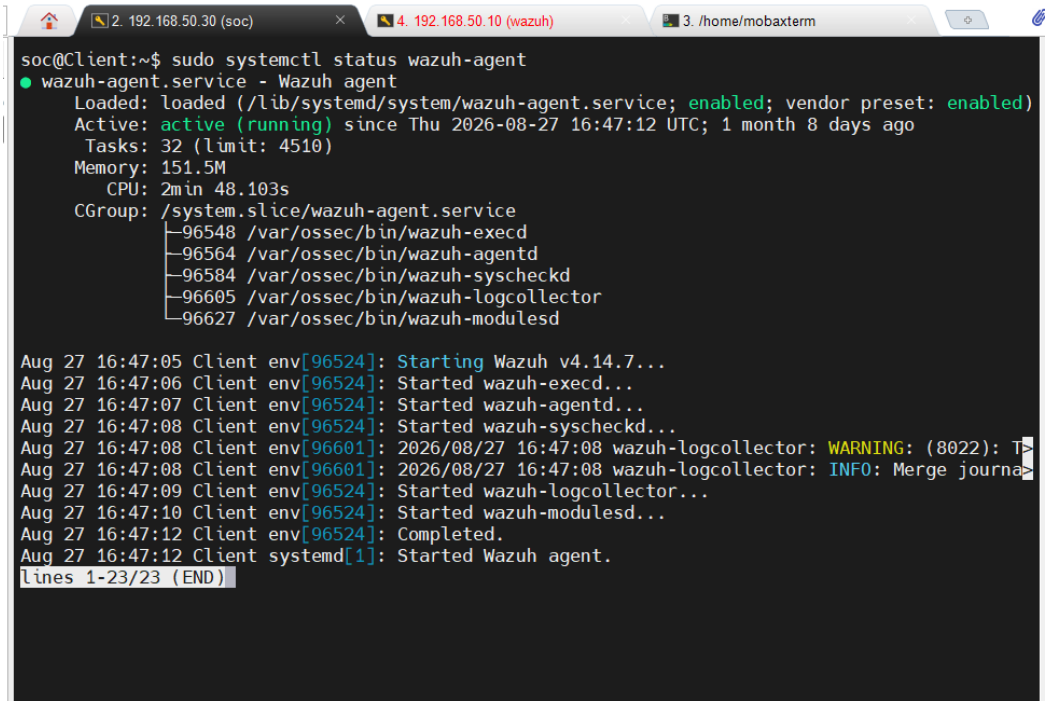


Capture d'écran 2.1 : Console FortiGate — tableau de bord, interfaces (port1 WAN 10.10.10.10, port2 LAN 192.168.50.1), politique LAN-to-WAN avec NAT, et activation de la journalisation Syslog vers 192.168.50.10.

La capture montre aussi la politique de filtrage principale : LAN (port2) vers WAN (port1) avec NAT activée, en inspection « flow-based », et la journalisation de toutes les sessions. L'accès d'administration (HTTPS, SSH, SNMP) n'est autorisé que sur les interfaces nécessaires.

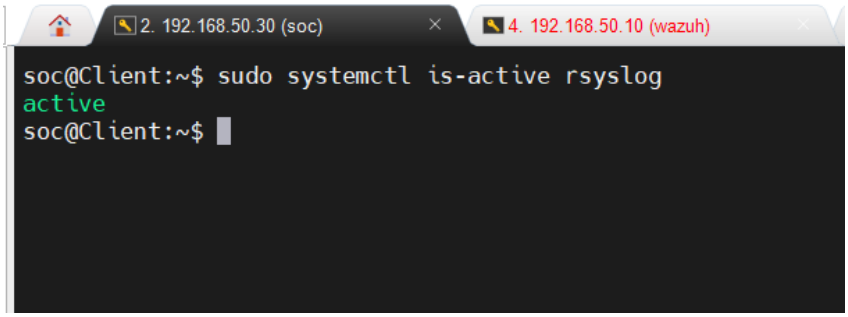
2.1.2 Source 2 — Ubuntu Client : agent Wazuh, rsyslog et auditd

Sur l'Ubuntu Client (192.168.50.30), un agent Wazuh est installé. C'est un petit programme qui lit les journaux locaux et les envoie au serveur, de façon chiffrée. La capture suivante montre le service actif depuis le 27 août 2026, avec ses cinq processus internes (execd, agentd, syscheckd, logcollector, modulesd) :



Capture d'écran 2.2 : Agent Wazuh actif (running) sur l'Ubuntu Client — version 4.14.7, service activé au démarrage.

Deux services complètent l'agent. rsyslog, le service historique de journaux Linux, est actif :



Capture d'écran 2.3 : Vérification du service rsyslog — état « active » sur l'Ubuntu Client.

auditd, l'outil d'audit avancé de Linux, enregistre les actions sensibles (modifications de /etc/passwd ou /etc/shadow, commandes privilégiées). La configuration de l'agent (ossec.conf) indique quels fichiers lire :

```
  <localfile>
    <log_format>syslog</log_format>
    <location>/var/ossec/logs/active-responses.log</location>
  </localfile>

  <localfile>
    <log_format>syslog</log_format>
    <location>/var/log/dpkg.log</location>
  </localfile>

<localfile>
    <location>/var/log/audit/audit.log</location>
    <log_format>audit</log_format>
  </localfile>

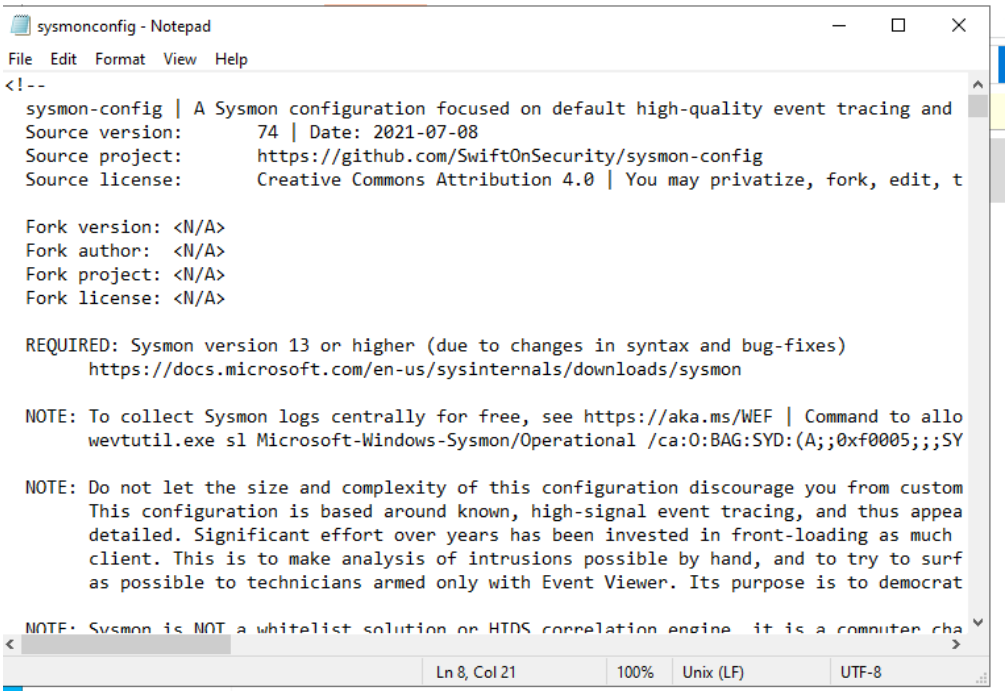

<localfile>
  <log_format>syslog</log_format>
  <location>/var/log/syslog</location>
</localfile>

<localfile>
  <log_format>syslog</log_format>
  <location>/var/log/kern.log</location>
</localfile>
```

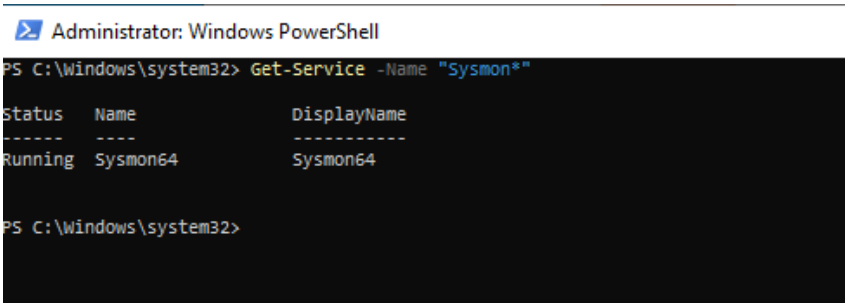
Capture d'écran 2.4 : Extrait de ossec.conf de l'agent Linux — lecture de /var/log/audit/audit.log (format audit), /var/log/syslog, /var/log/kern.log, /var/log/dpkg.log et des journaux de réponse active.

2.1.3 Source 3 — Windows Server 2022 : Sysmon, WEF et agent Wazuh

Windows possède déjà son journal d'événements (Event Log), mais il est peu détaillé sur les processus. Nous y ajoutons Sysmon (System Monitor), un outil gratuit de Microsoft qui enregistre finement chaque programme lancé, avec sa ligne de commande complète et ses empreintes (hashes). Sysmon est installé avec le profil de configuration SwiftOnSecurity, une référence mondiale qui filtre le bruit et garde les événements à forte valeur :

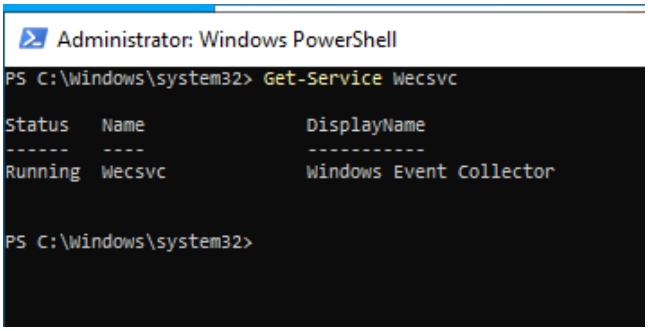


Capture d'écran 2.5 : Fichier de configuration Sysmon SwiftOnSecurity (version 74) — traçage d'événements à haute valeur, compatible Sysmon 13+.



Capture d'écran 2.6 : Service Sysmon64 en cours d'exécution sur Windows Server 2022 (Get-Service Sysmon).*

Le service WEF (Windows Event Forwarding, service Wecsvc) est également actif : il permet de centraliser les journaux Windows. L'agent Wazuh, lui, lit directement le canal Sysmon (Microsoft-Windows-Sysmon/Operational) au format eventchannel, puis transmet tout au SIEM.



Capture d'écran 2.7 : Service Wecsvc (Windows Event Collector) actif sur Windows Server 2022.

2.2 Normalisation et validation des logs

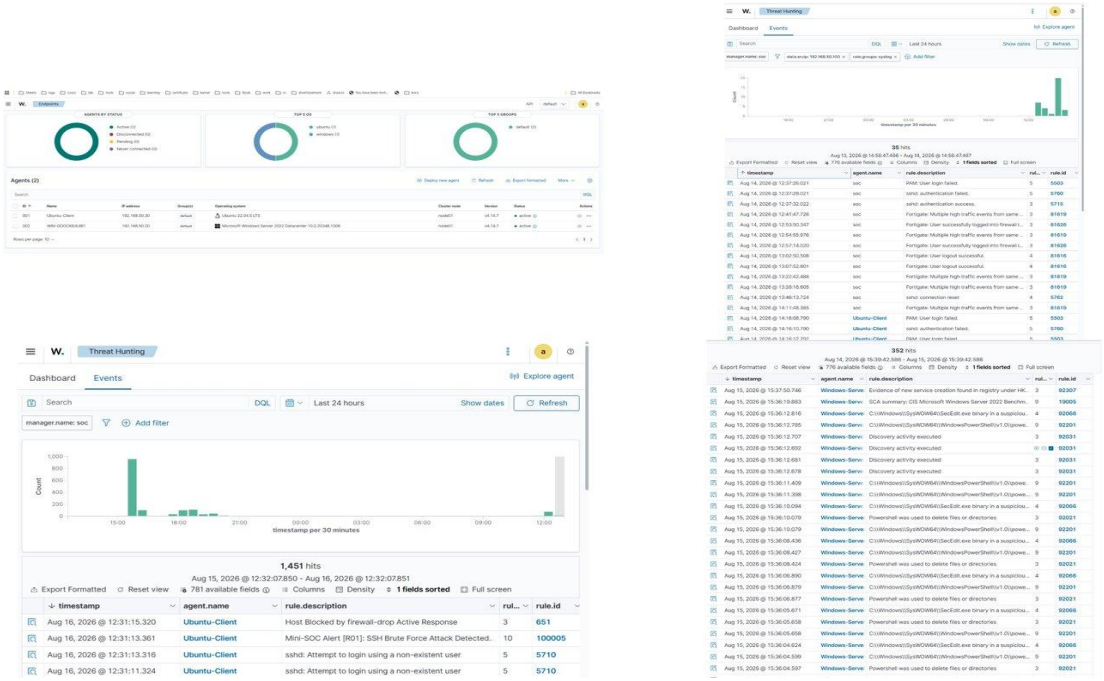
2.2.1 Normalisation : un même format pour toutes les sources

Chaque source écrit ses logs dans un format différent : lignes Syslog pour le FortiGate, journald pour Ubuntu, événements XML pour Windows. Wazuh normalise tout cela : des décodeurs découpent chaque ligne en champs structurés (adresse IP source, utilisateur, port...), puis le moteur produit un document JSON unique par événement. C'est cette uniformisation qui permet de corréler des sources différentes dans les mêmes tableaux de bord.

Exemple : un événement FortiGate devient un document JSON avec les champs data.srcip, data.dstip, decoder.name = fortigate-firewall-v5 ; un échec SSH devient un document avec decoder.name = sshd, data.srcuser, data.srcip, data.srcport.

2.2.2 Validation de la collecte

La capture suivante montre la preuve de bout en bout : les deux agents (001 Ubuntu-Client et 002 Windows Server) sont « active » dans la console Wazuh, et le module Threat Hunting affiche bien des événements venant des trois sources : logs FortiGate (connexions admin, trafic), logs SSH/PAM de l'Ubuntu, et événements Sysmon du Windows Server.



Capture d'écran 2.8 : Console Wazuh — agents connectés (Ubuntu-Client 192.168.50.30 et Windows Server 192.168.50.20 actifs) et événements collectés depuis les trois sources (FortiGate, sshd/PAM, Sysmon).

On y voit aussi un exemple d'alerte personnalisée déjà déclenchée (règle 100005, niveau 10) et une réponse active automatique (« Host Blocked by firewall-drop Active Response », règle 651) : la chaîne complète collecte → détection → réaction fonctionne.

2.2.3 Chiffrement des communications (ENF-04)

Le cahier des charges exige que les échanges entre agents et serveur soient chiffrés en TLS 1.2 ou plus. Nous l'avons vérifié avec un test de connexion OpenSSL depuis l'agent : la négociation aboutit en TLSv1.2 avec le chiffrement ECDHE-RSA-AES256-GCM-SHA384 et une clé serveur de 2048 bits.

```
SSL handshake has read 1444 bytes and written 281 bytes
Verification error: self-signed certificate
---
New, TLSv1.2, Cipher is ECDHE-RSA-AES256-GCM-SHA384
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1.2
    Cipher    : ECDHE-RSA-AES256-GCM-SHA384
    Session-ID: 5C47A8A63AEC536E8B2339D3505B2A263E5905733E7BFFBC181ACB6FF107583B
    Session-ID-ctx:
    Master-Key: B795017CCC704A929EA130671B03011585925015478197 3C37A9AC4487B275241B308B4E48E2EB
9F41B66066B5D2D196
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 7200 (seconds)
    TLS session ticket:
    0000 - fc cf ed cd 4c 4c c0 8f-f9 59 c1 82 15 c5 4a 3d   ....LL...Y....J=
    0010 - e3 69 55 ea 88 98 81 9c-6e fb 40 40 94 20 81 58   .iU.....n.@@. .X
    0020 - 63 65 8d 90 a6 f7 c3 68-f2 18 fd 49 cf 92 d7 c7   ce.....h...I....
    0030 - 99 10 41 1c 2c 30 81 8f-7c a4 a2 d5 c7 ea b4 91   ..A.,0..|.......
    0040 - e7 9d 07 2d 92 f0 8d 0c-90 fb ab 4c dc ca 12 9e   ...-.......L....
    0050 - 3e eb 66 fb 7b 2d fd e1-ca 9b e1 55 c2 4d b9 34   >.f.{-.....U.M.4
    0060 - 64 ed f5 7f c6 82 f7 40-d6 75 17 dc 61 2f a1 50   d......@.u..a/.P
    0070 - 87 d3 cd d5 90 a1 6d 61-7f b9 da 69 42 b1 63 68   ......ma...iB.ch
    0080 - ac f1 c5 31 87 0d 33 8b-58 26 d9 3a 98 89 64 5c   ...1..3.X&.:..d\
    0090 - 24 9d a9 55 98 08 40 89-6d 2e 52 83 10 81 e5 eb   $..U..@.m.R.....

    Start Time: 1791216470
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: yes
---
DONE
soc@Client:~$ p
```

Capture d'écran 2.9 : Test OpenSSL agent → serveur — session TLSv1.2, chiffrement ECDHE-RSA-AES256-GCM-SHA384 (le certificat auto-signé est attendu dans un laboratoire isolé).

2.3 Ruleset de détection personnalisé (R01 à R05)

2.3.1 Principe de fonctionnement des règles Wazuh

Une règle Wazuh est une consigne écrite en XML qui dit au SIEM : « si tu vois tel événement, tant de fois, en si peu de temps, déclenche une alerte ». Chaque règle possède un identifiant, un niveau de gravité (de 0 = informatif à 15 = critique), et peut citer une technique du catalogue MITRE ATT&CK. Nos règles personnalisées sont regroupées dans le fichier /var/ossec/etc/rules/local_rules.xml, versionné dans Git (voir section 4.1).

Trois paramètres reviennent souvent : frequency (combien d'événements), timeframe (en combien de secondes), et ignore (le temps d'attente avant de répéter la même alerte — c'est notre mécanisme anti-flood, exigence EF-10).

2.3.2 Tableau de synthèse du ruleset

ID	Scénario détecté	Règle Wazuh	Niveau / seuil	MITRE ATT&CK
R01	Force brute SSH	100005	10 — 5 échecs / 60 s, même IP	T1110 — Brute Force
R02	Scan de ports (Nmap)	100010 + 100011	10 — 10 paquets / 60 s, même IP	T1046 — Network Service Discovery
R03	Élévation de privilèges (sudo)	100002	10 — chaque commande sudo	T1548.003 — Sudo
R04	Exfiltration de données	100004	10 — téléchargement de .sql/.db/.zip/.bak/.csv	T1041 — Exfiltration Over C2
R05	Création de compte non autorisée	100003	10 — useradd / Event 4720	T1136 — Create Account
Bonus	Dump mémoire LSASS	100090	12 — motif comsvcs.dll + MiniDump	T1003.001 — LSASS Memory
Bonus	Exploit web Shellshock (CVE-2014-6271)	100012	12 — motif () { :; };	T1190 / T1059

2.3.3 R01 — Force brute SSH (règle 100005)

Une attaque par force brute consiste à essayer des centaines de mots de passe, un par un, jusqu'à trouver le bon. Wazuh possède déjà une règle standard (5710) qui repère chaque échec de connexion SSH. Notre règle 100005 les additionne : 5 échecs venus de la même IP en moins de 60 secondes déclenchent une alerte de niveau 10.

```
<rule id="100005" level="10" frequency="5" timeframe="60" ignore="300">
  <if_matched_sid>5710</if_matched_sid>
  <same_source_ip />
  <description>Mini-SOC Alert [R01]: SSH Brute Force Attack Detected from
$(srcip)</description>
  <mitre><id>T1110</id></mitre>
  <group>brute_force,authentication_failed,</group>
</rule>
```

2.3.4 R02 — Scan de ports (règles 100010 et 100011)

Un scan de ports est la phase de repérage d'une attaque : l'attaquant teste les « portes » de la machine pour trouver les services ouverts. Sur l'Ubuntu, le pare-feu local iptables journalise chaque paquet suspect dans /var/log/syslog. La détection se fait en deux étapes : la règle 100010 (niveau 3, informatif) note chaque paquet « iptables: » ; la règle 100011 (niveau 10) conclut à un scan quand 10 de ces événements arrivent de la même IP en moins de 60 secondes.

```
<rule id="100010" level="3">
  <if_sid>4100</if_sid>
  <match>iptables:</match>
  <description>Network connection attempt from $(srcip)</description>
</rule>

<rule id="100011" level="10" frequency="10" timeframe="60" ignore="300">
  <if_matched_sid>100010</if_matched_sid>
  <same_source_ip />
  <description>Mini-SOC Alert [R02]: Network Reconnaissance Detected from
$(srcip)</description>
  <mitre><id>T1046</id></mitre>
  <group>reconnaissance,network_scan,</group>
</rule>
```

2.3.5 R03 — Élévation de privilèges via sudo (règle 100002)

L'élévation de privilèges, c'est quand un utilisateur normal obtient des droits d'administrateur. Sous Linux, la commande sudo sert à cela. La règle standard Wazuh 5402 repère chaque sudo ; notre règle 100002 le signale immédiatement au niveau 10, car dans un serveur surveillé, toute élévation mérite l'attention de l'analyste.

```
<rule id="100002" level="10">
  <if_sid>5402</if_sid>
  <description>Mini-SOC Alert [R03]: Privilege Escalation - Command executed via
sudo</description>
  <mitre><id>T1548.003</id></mitre>
  <group>privilege_escalation,sudo,</group>
</rule>
```

2.3.6 R04 — Exfiltration de données (règle 100004)

L'exfiltration, c'est le vol de données : l'attaquant télécharge des fichiers sensibles depuis la machine compromise. Notre règle surveille les journaux du serveur web Apache et alerte dès qu'une adresse télécharge un fichier à extension sensible : .sql, .db, .zip, .bak ou .csv.

```
<rule id="100004" level="10">
  <if_sid>31100,31101,31108</if_sid>
  <url>.sql|.db|.zip|.bak|.csv</url>
  <description>Mini-SOC Alert [R04]: Potential Data Exfiltration - Sensitive File
Downloaded</description>
  <mitre><id>T1041</id></mitre>
  <group>exfiltration,web_attack,</group>
</rule>
```

2.3.7 R05 — Création de compte non autorisée (règle 100003)

Pour garder un accès durable à une machine, un attaquant crée souvent son propre compte utilisateur. Notre règle surveille les événements de création de compte (règles Wazuh 60109 et 5902 : useradd sous Linux, Event ID 4720 sous Windows) et alerte au niveau 10.

```
<rule id="100003" level="10">
  <if_sid>60109,5902</if_sid>
  <description>Mini-SOC Alert [R05]: New user account created on $(hostname)</description>
  <mitre><id>T1136</id></mitre>
  <group>account_creation,</group>
</rule>
```

2.3.8 Règles complémentaires : dump LSASS et exploit Shellshock

Au-delà des 5 règles exigées, deux détections de niveau critique (12) ont été ajoutées. La première repère le dump de la mémoire LSASS sous Windows — la technique qui permet de voler les mots de passe — en cherchant le motif « comsvcs.dll ... MiniDump » dans les lignes de commande enregistrées par Sysmon. La seconde repère l'exploitation de la faille web Shellshock (CVE-2014-6271) via sa signature « () { :; }; » dans les journaux Apache.

```
<rule id="100090" level="12">
  <if_group>sysmon_event1</if_group>
  <field name="win.eventdata.commandLine" type="pcre2">(?i)comsvcs\.dll.*MiniDump</field>
  <description>CRITICAL: Suspicious LSASS memory dump via comsvcs.dll detected</description>
  <mitre><id>T1003.001</id></mitre>
</rule>

<rule id="100012" level="12">
  <if_sid>31100,31108</if_sid>
  <match>() { :; };</match>
  <description>Mini-SOC Alert [CVE Exploit]: Attempted RCE / Shellshock
Exploitation</description>
  <mitre><id>T1190</id><id>T1059</id></mitre>
  <group>exploit_cve,web_attack,</group>
</rule>
```

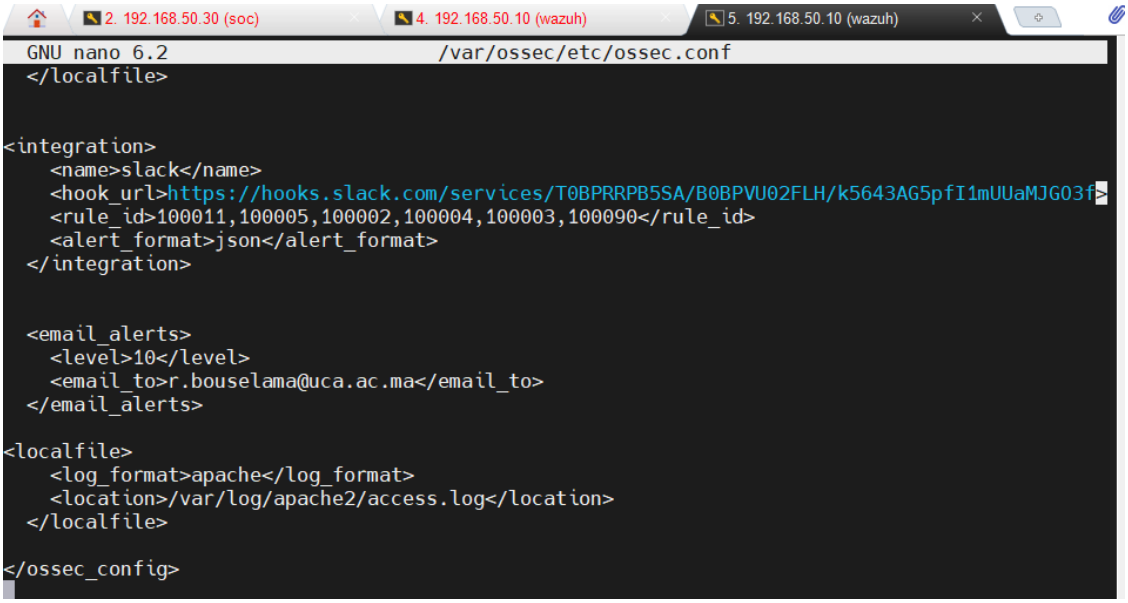
Des règles FortiGate complètent le dispositif : 100050 (échec de connexion administrateur au pare-feu, niveau 8), 100051 (connexion admin réussie, niveau 3) et 100080 (trafic élevé / reconnaissance depuis le WAN, niveau 10).

3. Alerting, tableaux de bord et simulations d'attaques

3.1 Moteur d'alerte en temps réel

Détecter ne suffit pas : il faut prévenir tout de suite les analystes. Deux canaux de notification sont configurés dans le fichier /var/ossec/etc/ossec.conf du serveur Wazuh :

- **E-mail :** un message est envoyé à l'adresse e-mail de l'équipe SOC pour toute alerte de niveau 10 ou plus (bloc email_alerts, level = 10).
- **Slack :** un message est posté sur le canal « Mini-SOC Alerts » via un webhook, uniquement pour nos règles personnalisées (rule_id 100011, 100005, 100002, 100004, 100003, 100090), au format JSON.



Capture d'écran 3.1 : Configuration des alertes dans ossec.conf — intégration Slack (webhook, liste des règles) et alertes e-mail (niveau ≥ 10).

3.1.1 Niveaux de sévérité (exigence EF-09)

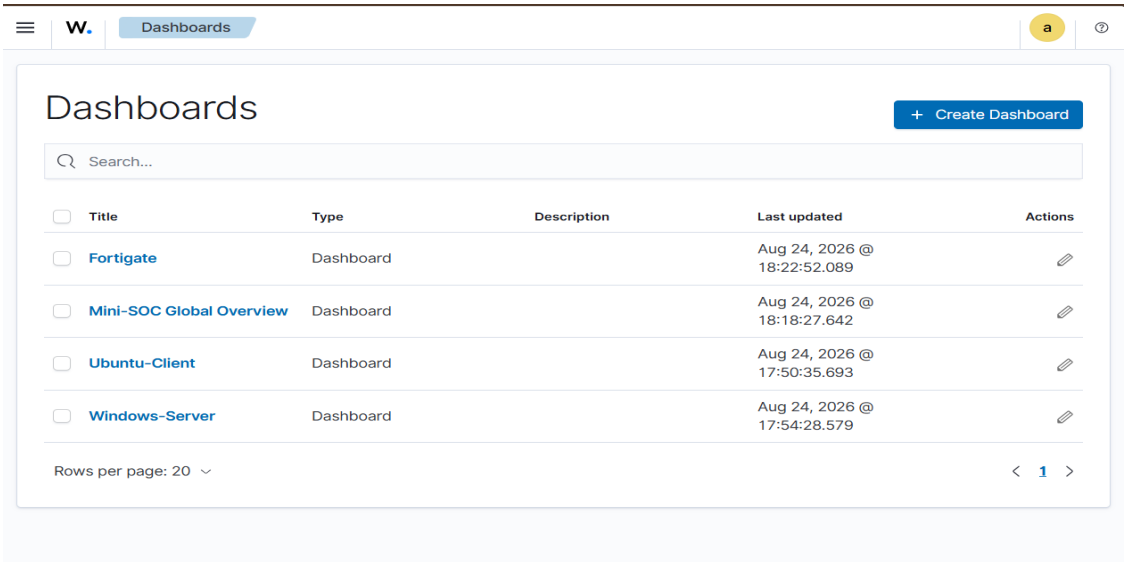
Niveau Wazuh	Sévérité	Action attendue
0 à 3	Informatif	Journaliser, aucune action immédiate
4 à 6	Bas	Vérifier à la prochaine revue
7 à 9	Moyen	Analyse par l'analyste de garde
10 à 11	Élevé	Réponse immédiate + alerte e-mail / Slack
12 et plus	Critique	Réponse immédiate, escalade, rapport d'incident obligatoire

3.1.2 Anti-flood (exigence EF-10)

Pour éviter d'inonder l'équipe de messages identiques, chaque règle d'alerte porte le paramètre ignore=300 : une fois déclenchée, la même alerte ne peut pas se répéter pendant 5 minutes (300 secondes). Ce réglage est visible dans les règles 100005, 100011 et 100080 de la section 2.3.

3.2 Tableaux de bord de supervision

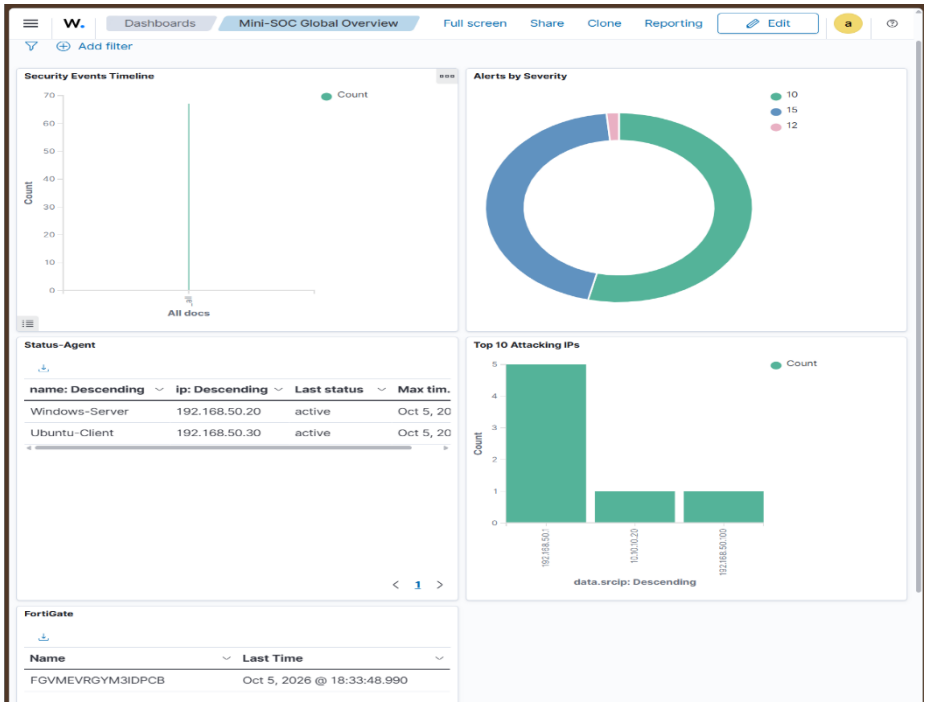
Quatre tableaux de bord ont été construits dans le Wazuh Dashboard, conformément aux exigences EF-11 à EF-13 : une vue globale et une vue par source.



Capture d'écran 3.2 : Liste des quatre tableaux de bord — Mini-SOC Global Overview, Fortigate, Ubuntu-Client et Windows-Server.

3.2.1 Vue globale — Mini-SOC Global Overview

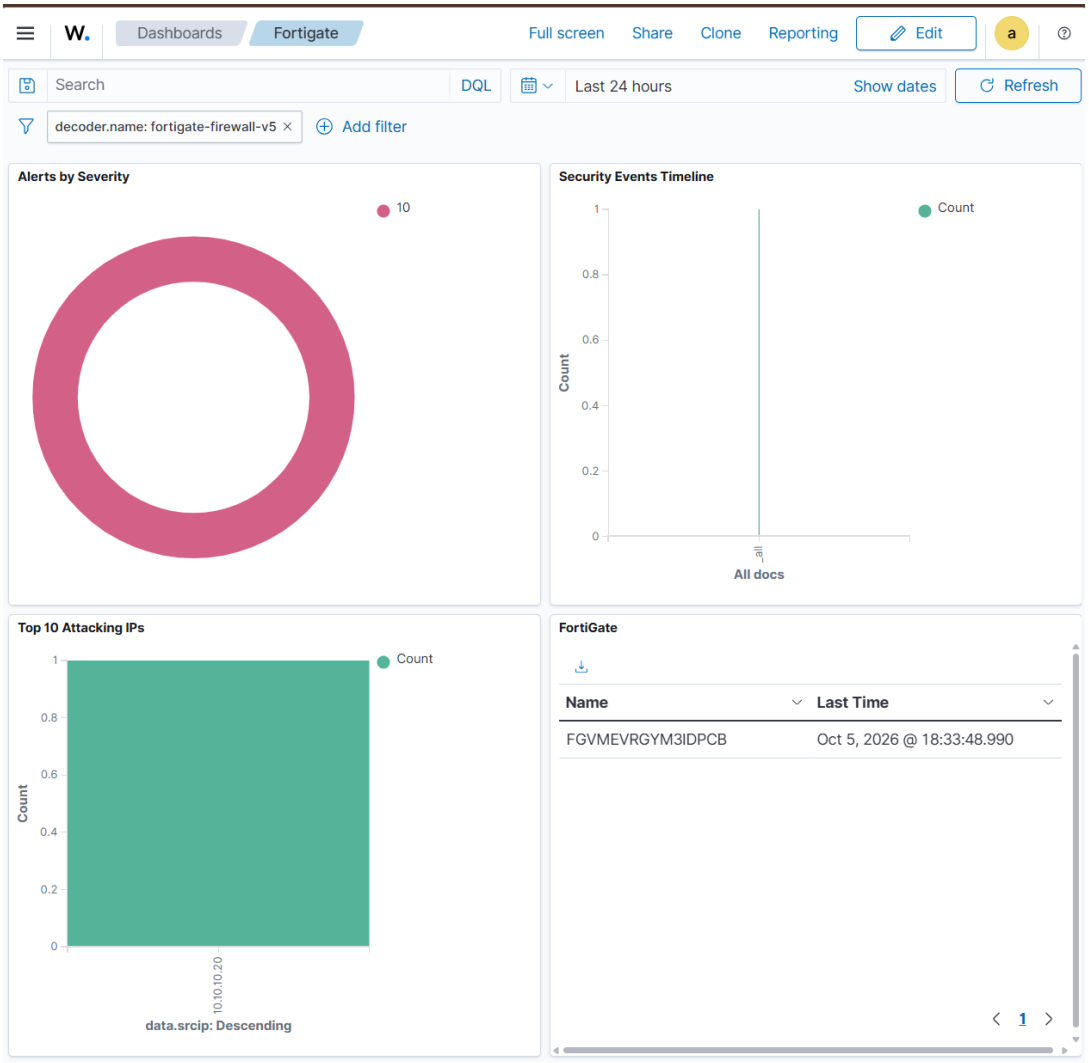
Le tableau de bord principal réunit les indicateurs essentiels : la timeline des événements de sécurité, la répartition des alertes par sévérité (niveaux 10, 12, 15), le statut des agents en temps réel (EF-13), le top 10 des adresses IP attaquantes et la liste des pare-feux FortiGate vus.



Capture d'écran 3.3 : Dashboard « Mini-SOC Global Overview » — timeline, alertes par sévérité, statut des agents (actifs) et top 10 des IP sources (192.168.50.1, 10.10.10.20, 192.168.50.100).

3.2.2 Dashboard FortiGate

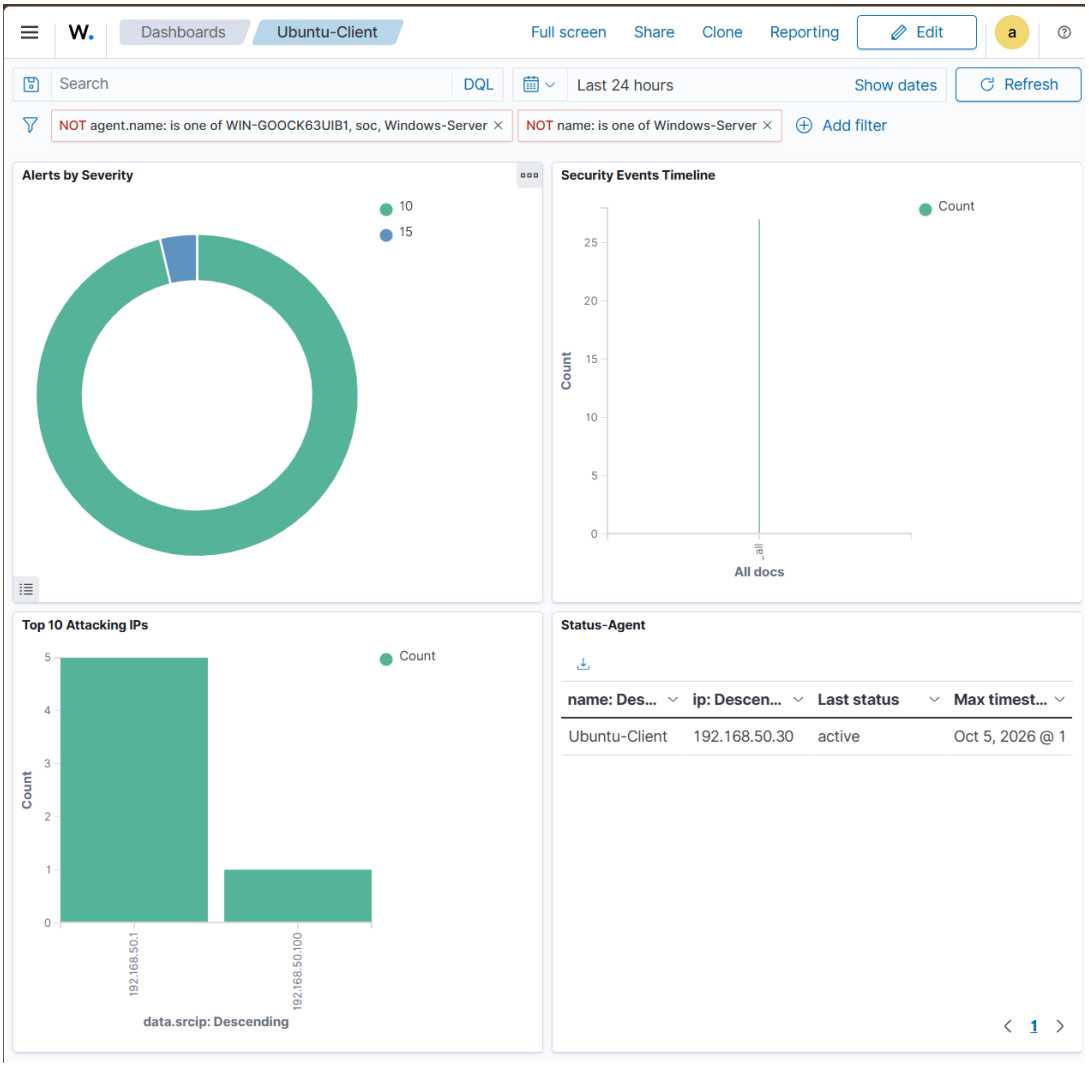
Ce tableau filtre les événements du décodeur fortigate-firewall-v5 : alertes par sévérité, timeline, top des IP attaquantes et dernier événement reçu du pare-feu (FGVMEVRGYM3IDPCB).



Capture d'écran 3.4 : Dashboard FortiGate — alertes de sévérité 10, top IP attaquante (10.10.10.20) et dernier événement du pare-feu (5 octobre 2026, 18:33).

3.2.3 Dashboard Ubuntu-Client

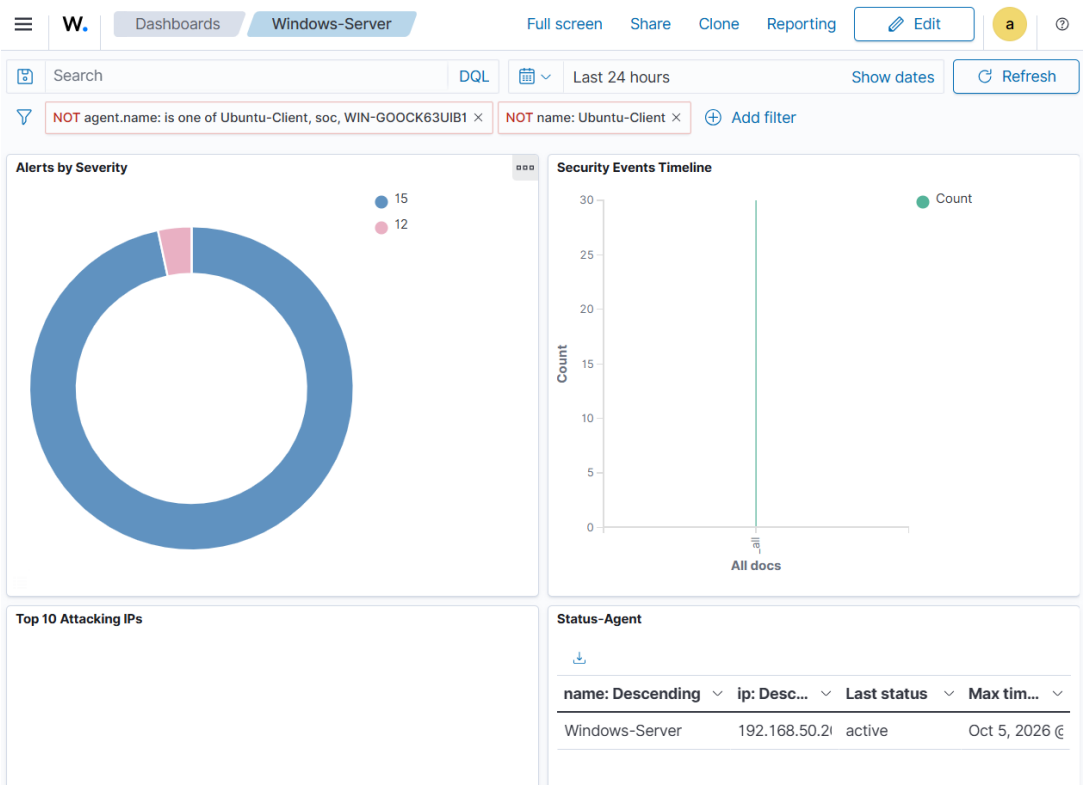
Ce tableau filtre les événements de l'agent Ubuntu : alertes de niveau 10 et 15, IP sources les plus actives (192.168.50.1 et 192.168.50.100) et statut de l'agent (actif).



Capture d'écran 3.5 : Dashboard Ubuntu-Client — répartition des sévérités, timeline et statut de l'agent 192.168.50.30.

3.2.4 Dashboard Windows-Server

Ce tableau suit le serveur Windows : alertes de niveau 12 et 15 (dont le dump LSASS), timeline et statut de l'agent 192.168.50.20.



Capture d'écran 3.6 : Dashboard Windows-Server — alertes de niveaux 12 et 15, statut de l'agent actif.

3.3 Simulations d'attaques et synthèses d'incidents (ISO 27035)

Pour prouver que le Mini-SOC fonctionne, sept scénarios d'attaque ont été joués depuis le Kali Linux (ou localement sur les serveurs), tous dans le réseau virtuel isolé. Chaque scénario a été détecté, alerté et documenté dans un rapport d'incident conforme à la norme ISO/IEC 27035 : chronologie, indicateurs de compromission (IoC), techniques MITRE ATT&CK, actions de remédiation et leçons apprises. Les trois rapports complets (R01, R02, R03) sont des livrables séparés ; cette section en présente la synthèse.

3.3.1 Scénario 1 — Force brute SSH (règle R01)

Attaque : depuis le Kali, une boucle de 6 tentatives SSH avec le compte inexistant « invaliduser » vers l'Ubuntu Client (192.168.50.30).

Détection : le 30 septembre 2026 à 17:05:49, la règle 100005 (niveau 10) se déclenche après 5 échecs en moins de 60 secondes. Le journal montre « Invalid user invaliduser from 192.168.50.1 port 40004 » — l'IP 192.168.50.1 est en réalité le Kali 10.10.10.20 derrière la NAT du FortiGate. Notification Slack reçue à 17:05.

Résultat : aucune connexion réussie. L'attaquant est ensuite bloqué par une politique DENY sur le FortiGate. Incident INC-2026-001 clôturé.



Capture d'écran 3.7 : Scénario 1 — règle 100005, document JSON de l'alerte (agent 001, srcip 192.168.50.1, port 40004) et notification Slack (niveau 10).

3.3.2 Scénario 2 — Reconnaissance réseau, scan Nmap (règle R02)

Attaque : nmap -sS -p 1-100 -T4 192.168.50.30 — un scan SYN des 100 premiers ports de l'Ubuntu Client.

Détection : la règle 100011 (niveau 10) se déclenche deux fois le 30 septembre : à 17:00:50 (paquet SYN vers le port 21, TTL 52) et à 18:49:30 (paquet SYN vers le port 80, TTL 63). Le seuil de 10 paquets en 60 secondes depuis la même IP a transformé la rafale en une seule alerte claire, notifiée sur Slack à 18:49.

Résultat : scan identifié, aucune exploitation après le scan. Incident INC-2026-002 clôturé. Enchaînement classique observé : le scan (R02) a précédé de quelques minutes la force brute (R01) — même campagne, même source.

```
<!-- Generate ONE alert after repeated activity -->
<rule id="100011" level="10" frequency="10" timeframe="60" ignore="300">
  <if_matched_sid>100010</if_matched_sid>
  <same_source_ip />
  <description>Mini-SOC Alert [R02]: Network Reconnaissance Detected from $
(srcip)</description>
  <mitre>
    <id>T1046</id>
  </mitre>
  <group>reconnaissance,network_scan,</group>
</rule>
```

t	_index	wazuh-alerts-4.x-2026.09.30
t	agent.id	001
t	agent.ip	192.168.50.30
t	agent.name	Ubuntu-Client
t	data.action	iptables:
t	data.dstip	192.168.50.30
t	data.dstport	21
t	data.protocol	TCP
t	data.srcip	192.168.50.1
t	data.srcport	44854
t	decoder.name	kernel
t	decoder.parent	kernel
t	full_log	Sep 30 17:00:50 Cli l: [81529.360715] iptables: IN=ens33 OUT= MAC=00:0c:29:9 f:c7:c2:00:0c:29:a8:42:78:0 8:00 SRC=192.168.50.1 DST=19 2.168.50.30 LEN=44 TOS=0x00 PREC=0x00 TTL=52 ID=52795 PR OTO=TCP SPT=44854 DPT=21 WIN DOW=1024 RES=0x00 SYN URGP=0
t	id	1790787652.18248537
t	input.type	log
t	location	/var/log/syslog
t	manager.name	soc
t	predecoder.hostname	Client
t	predecoder.program_name	kernel
t	predecoder.timestamp	Sep 30 17:00:50
t	previous_output	Sep 30 17:00:50 Client ker nel: [81529.360712] iptabl es: IN=ens33 OUT= MAC=00:0 c:29:9f:c7:c2:00:0c:29:a8: 42:78:08:00 SRC=192.168.5 0.1 DST=192.168.50.30 LEN= 44 TOS=0x00 PREC=0x00 TTL=
t	rule.description	Mini-SOC Alert [R02]: Networ k Reconnaissance Detected fr om 192.168.50.1

WAZUH Alert

Mini-SOC Alert [R02]: Network Reconnaissance Detected from 192.168.50.1
Sep 30 18:49:30 Client kernel: [88048.680345] iptables: IN=ens33 OUT=
MAC=00:0c:29:9f:c7:c2:00:0c:29:a8:42:78:08:00 SRC=192.168.50.1
DST=192.168.50.30 LEN=60 TOS=0x00 PREC=0x00 TTL=63 ID=56143 DF
PROTO=TCP SPT=39794 DPT=80 WINDOW=64240 RES=0x00 SYN URGP=0

Agent
(001) - Ubuntu-Client

Location
/var/log/syslog

Rule ID
100011 *(Level 10)*

Today at 6:49 PM

Capture d'écran 3.8 : Scénario 2 — règles 100010/100011, paquet iptables SYN (SPT=44854, DPT=21) et notification Slack (niveau 10).

3.3.3 Scénario 3 — Dump mémoire LSASS sur Windows (règle 100090)

Attaque : sur le Windows Server, depuis PowerShell en administrateur : cmd.exe /c "echo comsvcs.dll MiniDump" — la signature exacte de la technique de vol d'identifiants par dump LSASS (MITRE T1003.001).

Détection : le 1er octobre 2026 à 14:37:28, la règle 100090 (niveau 12, CRITIQUE) reconnaît le motif dans la ligne de commande enregistrée par Sysmon (Event ID 1). L'alerte montre toute la chaîne : powershell.exe (PID 6812) → cmd.exe, utilisateur WIN-GOOCK63UIB1\Win-Soc, intégrité « High », avec les empreintes MD5/SHA256 du programme. E-mail d'alerte reçu à 14:37.

Résultat : simulation détectée immédiatement, aucun vol réel. Incident INC-2026-003 clôturé.

```
<!-- Suspicious LSASS memory dump -->
  <rule id="100090" level="12">
    <if_group>sysmon_event1</if_group>
    <field name="win.eventdata.commandLine" type="pcre2">(?i)comsvcs\.dll.*MiniDump</field>
    <description>CRITICAL: Suspicious LSASS memory dump via comsvcs.dll detected</description>
    <mitre>
      <id>T1003.001</id>
    </mitre>
  </rule>
```

t	_index	wazuh-alerts-4.x-2026.10.01
t	agent.id	003
t	agent.ip	192.168.50.20
t	agent.name	Windows-Server
t	data.win.eventdata.commandLine	\"C:\\Windows\\system32\\cmd.exe\" /c \"echo comsvcs.dll MiniDump\"
t	data.win.eventdata.company	Microsoft Corporation
t	data.win.eventdata.currentDirectory	C:\\Windows\\system32\\
t	data.win.eventdata.description	Windows Command Processor
t	data.win.eventdata.fileVersion	10.0.20348.1 (WinBuild.160101.0800)
t	data.win.eventdata.hashes	MD5=E7A6B1F51EFB405287A8048CFA4690F4,SHA256=EB71EA69DD19F728AB9240565E8C7EFB59821E19E3788E289301E1E74940C208,IMPHASH=D60B77062898DC6BFAE7FE11A0F8806C
t	data.win.eventdata.image	C:\\Windows\\System32\\cmd.exe
t	data.win.eventdata.integrityLevel	High
t	data.win.eventdata.logonGuid	{806c71d4-089a-6ab0-c235-0a0000000000}
t	data.win.eventdata.logonId	0xa35c2
t	data.win.eventdata.originalFileName	Cmd.Exe
t	data.win.eventdata.parentCommandLine	\"C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe\"
t	data.win.eventdata.parentImage	C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe
t	data.win.eventdata.parentProcessGuid	{806c71d4-08c3-6ab0-2e01-000000000700}
t	data.win.eventdata.parentProcessId	6812
t	data.win.eventdata.parentUser	WIN-GOOCK63UIB1\\Win-Soc

Wazuh notification - (Windows-Server) any - Alert level 12 Inbox ×

Wazuh <r.bouselama@uca.ac.ma> 14:37 (1 minute ago)
to me

Wazuh Notification.
2026 Oct 01 14:37:28

Received From: (Windows-Server) any->EventChannel
Rule: 100090 fired (level 12) -> "CRITICAL: Suspicious LSASS memory dump via comsvcs.dll detected"
User: WIN-GOOCK63UIB1\Win-Soc
Portion of the log(s):

{"win":{"system":{"providerName":"Microsoft-Windows-Sysmon","providerGuid":"{5770385f-c22a-43e0-bf4c-06f5698ffbd9}","eventID":"1","version":"5","level":"4","task":"1","opcode":"0","keywords":"0x8000000000000000","systemTime":"2026-10-01T14:37:25.0683051Z","eventRecordID":"5187","processID":"2496","threadID":"4188","channel":"Microsoft-Windows-Sysmon/Operational","computer":"WIN-GOOCK63UIB1","severityValue":"INFORMATION","message":"\"Process

Capture d'écran 3.9 : Scénario 3 — règle 100090 (niveau 12), document JSON Sysmon (ligne de commande, processus parent PowerShell, hashes) et e-mail d'alerte critique.

3.3.4 Scénario 3 bis — Élévation de privilèges via sudo (règle R03)

Attaque : sur l'Ubuntu Client, exécution de commandes avec sudo, dont sudo cat /etc/shadow (lecture du fichier des mots de passe).

Détection : le 30 septembre à 18:30:09 puis 19:33:09, la règle 100002 (niveau 10) signale chaque commande sudo : utilisateur « soc » passant root, TTY=pts/2. Notification Slack reçue à 19:33 avec la commande complète (/usr/bin/cat /etc/shadow).



```
<!-- R03: Privilege Escalation -->
  <rule id="100002" level="10">
    <if_sid>5402</if_sid>
    <description>Mini-SOC Alert [R03]: Privilege Escalation - Command executed
via sudo</description>
    <mitre>
      <id>T1548.003</id>
    </mitre>
    <group>privilege_escalation,sudo,</group>
  </rule>
```

t	_index	wazuh-alerts-4.x-2026.09.30
t	agent.id	001
t	agent.ip	192.168.50.30
t	agent.name	Ubuntu-Client
t	data.command	/usr/bin/tail -n 2 /var/log/apache2/access.log
t	data.dstuser	root
t	data.pwd	/home/soc
t	data.srcuser	soc
t	data.tty	pts/2
t	decoder.ftscomment	First time user executed the sudo command
t	decoder.name	sudo
t	decoder.parent	sudo
t	full_log	Sep 30 18:30:09 Client sudo [163816]: soc : TTY=pts/2 ; PWD=/home/soc ; USER=root ; COMMAND=/usr/bin/tail -n 2 /var/log/apache2/access.log
t	id	1790793010.18267276
t	input.type	log
t	location	journald
t	manager.name	soc
t	predecoder.hostname	Client
t	predecoder.program_name	sudo
t	predecoder.timestamp	Sep 30 18:30:09
t	rule.description	Mini-SOC Alert [R03]: Privilege Escalation - Command executed via sudo
#	rule.firedtimes	1
t	rule.groups	local, custom_soc_rules, privilege_escalation, sudo
t	rule.id	100002
#	rule.level	10
◔	rule.mail	true

Capture d'écran 3.10 : Scénario 3 bis — règle 100002, document JSON (sudo, srcuser soc, dstuser root) et notification Slack (niveau 10).

3.3.5 Scénario 4 — Exfiltration de données (règle R04)

Attaque : depuis le Kali : curl http://192.168.50.30/confidential_database.sql — téléchargement d'un fichier sensible sur le serveur web de l'Ubuntu.

Détection : le 30 septembre à 19:09:04, la règle 100004 (niveau 10) repère l'extension .sql dans le journal Apache (GET /confidential_database.sql, client curl/8.20.0). Notification Slack à 19:09. La règle est reliée à la technique MITRE T1041 (exfiltration).

```
<!-- R04: Web Exfiltration Attempt -->
  <rule id="100004" level="10">
    <if_sid>31100,31101,31108</if_sid>
    <match>\.sql|\.db|\.zip|\.bak|\.csv</match>
    <description>Mini-SOC Alert [R04]: Potential Data Exfiltration - Sensitive
File Downloaded from Host by $(srcip)</description>
    <mitre>
      <id>T1041</id>
    </mitre>
    <group>exfiltration,web_attack,</group>
  </rule>
```

t	_index	wazuh-alerts-4.x-2026.09.30
t	agent.id	001
t	agent.ip	192.168.50.30
t	agent.name	Ubuntu-Client
t	data.id	404
t	data.protocol	GET
t	data.srcip	192.168.50.1
t	data.url	/confidential_database.sql
t	decoder.name	web-accesslog
t	full_log	192.168.50.1 - - [30/Sep/2026:19:09:04 +0000] "GET /confidential_database.sql HTTP/1.1" 404 436 "-" "curl/8.20.0"
t	id	1790795345.18277707
t	input.type	log
t	location	/var/log/apache2/access.log
t	manager.name	soc
t	rule.description	Mini-SOC Alert [R04]: Potential Data Exfiltration - Sensitive File Downloaded from Host by 192.168.50.1
#	rule.firedtimes	1
t	rule.groups	local, custom_soc_rules, exfiltration, web_attack
t	rule.id	100004
#	rule.level	10
◕	rule.mail	true
t	rule.mitre.id	T1041
t	rule.mitre.tactic	Exfiltration
t	rule.mitre.technique	Exfiltration Over C2 Channel
🗓	timestamp	Sep 30, 2026 @ 19:09:05.876

Mini-SOC Alerts APP 7:09 PM
WAZUH Alert

Mini-SOC Alert [R04]: Potential Data Exfiltration - Sensitive File Downloaded from Host by 192.168.50.1
192.168.50.1 - - [30/Sep/2026:19:09:04 +0000] "GET /confidential_database.sql HTTP/1.1" 404 436 "-" "curl/8.20.0"
Agent
(001) - Ubuntu-Client
Location
/var/log/apache2/access.log
Rule ID
100004 *(Level 10)*
Today at 7:09 PM

Capture d'écran 3.11 : Scénario 4 — règle 100004, document JSON (GET /confidential_database.sql, srcip 192.168.50.1) et notification Slack (niveau 10).

3.3.6 Scénario 5 — Création de compte non autorisée (règle R05)

Attaque : sur l'Ubuntu Client : sudo useradd — création de comptes « malicious_user » (UID 1001) puis « malicious_user1 » (UID 1002).

Détection : le 30 septembre à 19:14:30 et 19:16:51, la règle 100003 (niveau 10) signale chaque création de compte (décodeur useradd). Notification Slack à 19:16. Technique MITRE T1136 (persistence par création de compte).

```
<!-- R05: Unauthorized Account Creation -->
<rule id="100003" level="10">
  <if_sid>60109,5902</if_sid>
  <description>Mini-SOC Alert [R05]: New user account created on $(hostname)</
/description>
  <mitre>
    <id>T1136</id>
  </mitre>
  <group>account_creation,</group>
</rule>

</group>
```

t	_index	wazuh-alerts-4.x-2026.09.30
t	agent.id	001
t	agent.ip	192.168.50.30
t	agent.name	Ubuntu-Client
t	data.dstuser	malicious_user
t	data.gid	1001
t	data.home	/home/malicious_user
t	data.shell	/bin/sh,
t	data.uid	1001
t	decoder.name	useradd
t	decoder.parent	useradd
t	full_log	Sep 30 19:14:30 Client useradd[166421]: new user: name=malicious_user, UID=1001, GID=1001, home=/home/malicious_user, shell=/bin/sh, from=/dev/pts/0
t	id	1790795672.18278132
t	input.type	log
t	location	journald
t	manager.name	soc
t	predecoder.hostname	Client
t	predecoder.program_name	useradd
t	predecoder.timestamp	Sep 30 19:14:30
t	rule.description	Mini-SOC Alert [R05]: New user account created on Ubuntu-Client
#	rule.firedtimes	1
t	rule.groups	local, custom_soc_rules, account_creation
t	rule.id	100003
#	rule.level	10
◕	rule.mail	true
t	rule.mitre.id	T1136
t	rule.mitre.tactic	Persistence

Mini-SOC Alerts APP 7:16 PM
WAZUH Alert

Mini-SOC Alert [R05]: New user account created on Ubuntu-Client
Sep 30 19:16:51 Client useradd[166566]: new user: name=malicious_user1, UID=1002, GID=1002, home=/home/malicious_user1, shell=/bin/sh, from=/dev/pts/0
Agent
(001) - Ubuntu-Client
Location
journald
Rule ID
100003 *(Level 10)*
Today at 7:16 PM

Capture d'écran 3.12 : Scénario 5 — règle 100003, document JSON (new user malicious_user, UID=1001) et notification Slack (niveau 10).

3.3.7 Scénario 6 — Exploitation web Shellshock, CVE-2014-6271 (règle 100012)

Attaque : depuis le Kali : curl -A "() { :; }; /bin/eject" http://192.168.50.30/ — tentative d'exécution de commande à distance via la faille Shellshock.

Détection : la règle standard Wazuh 31168 (niveau 15, « Shellshock attack detected », CVE-2014-6271) et notre règle 100012 (niveau 12) repèrent la signature « () { :; }; » dans le journal Apache. Notification Slack reçue le 24 septembre à 15:57.

```
<group name="local,web,exploitation,cve,">
  <rule id="100012" level="12">
    <if_sid>31100, 31108</if_sid>
    <match>() { :; };</match>
    <description>Mini-SOC Alert [CVE Exploit]: Attempted RCE / Shellshock
Exploitation against Web Server from $(srcip)</description>
    <mitre>
      <id>T1190</id>
      <id>T1059</id>
    </mitre>
    <group>exploit_cve,web_attack,</group>
  </rule>
</group>
```

t	_index	wazuh-alerts-4.x-2026.09.30
t	agent.id	001
t	agent.ip	192.168.50.30
t	agent.name	Ubuntu-Client
t	data.id	200
t	data.protocol	GET
t	data.srcip	192.168.50.1
t	data.url	/
t	decoder.name	web-accesslog
t	full_log	192.168.50.1 - - [30/Sep/2026:15:31:20 +0000] "GET / HTTP/1.1" 200 10926 "-" "() { :; }; /bin/eject"
t	id	1790782280.18160770
t	input.type	log
t	location	/var/log/apache2/access.log
t	manager.name	soc
t	rule.description	Shellshock attack detected
#	rule.firedtimes	4
t	rule.gdpr	IV_35.7.d
t	rule.groups	web, accesslog, att
t	rule.id	31168
t	rule.info	CVE-2014-6271https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271
#	rule.level	15
◕	rule.mail	true
t	rule.mitre.id	T1068 T1190
t	rule.mitre.tactic	Privilege Escalation, Initial Access
t	rule.mitre.technique	Exploitation for Privilege Escalation, Exploit Public-Facing Application
t	rule.nist_800_53	SI.4
t	rule.pci_dss	11.4

Mini-SOC Alerts APP 3:57 PM
WAZUH Alert

Shellshock attack detected
192.168.50.1 - - [24/Sep/2026:15:57:32 +0000] "GET / HTTP/1.1" 200 10926 "-" "() { :; }; /bin/eject"
Agent
(001) - Ubuntu-Client
Location
/var/log/apache2/access.log
Rule ID
31168 *(Level 15)*
Sep 24th

Capture d'écran 3.13 : Scénario 6 — règle 100012 et règle 31168 (niveau 15), document JSON (User-Agent malveillant) et notification Slack.

3.3.8 Tableau récapitulatif des simulations

Scénario	Attaque	Règle / niveau	Détecté	Notification
1	Force brute SSH sur Ubuntu	100005 / 10	Oui — 30/09 17:05:49	Slack 17:05
2	Scan Nmap -sS ports 1-100	100011 / 10	Oui — 30/09 17:00 et 18:49	Slack 18:49
3	Dump LSASS (comsvcs.dll MiniDump)	100090 / 12	Oui — 01/10 14:37:28	E-mail 14:37
3 bis	Élévation sudo (cat /etc/shadow)	100002 / 10	Oui — 30/09 18:30 / 19:33	Slack 19:33
4	Exfiltration (.sql via HTTP)	100004 / 10	Oui — 30/09 19:09:04	Slack 19:09
5	Création de comptes (useradd)	100003 / 10	Oui — 30/09 19:14 / 19:16	Slack 19:16
6	Shellshock CVE-2014-6271	100012 + 31168 / 12-15	Oui — 24/09 15:57	Slack 15:57

4. Gouvernance, tests, difficultés et conclusion

4.1 Gouvernance opérationnelle et artefacts de réponse

4.1.1 Organisation de l'équipe SOC (mini RACI)

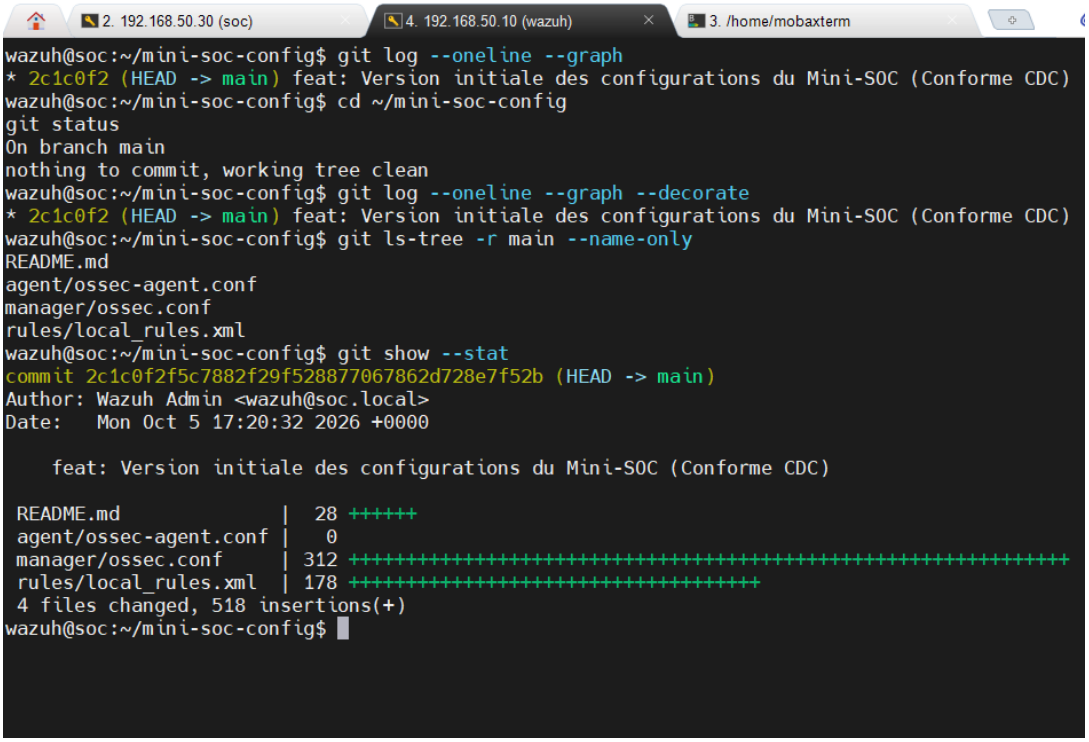
Rôle	Porteur	Responsabilité
Analyste SOC	Équipe projet	Surveille les alertes, exécute les playbooks, rédige les rapports
Administrateur système	Équipe projet	Applique les corrections (pare-feu, serveurs, comptes)
Encadrant	Enseignant	Valide l'architecture, les actions sensibles et les rapports

4.1.2 Méthode de réponse ISO/IEC 27035

Chaque incident suit les cinq phases de la norme : identification (lire l'alerte, vérifier les IoC), enregistrement (créer la fiche incident), confinement (bloquer l'IP au FortiGate, couper le compte), éradication et rétablissement (nettoyer, vérifier, rouvrir), puis clôture (rapport et leçons apprises). Règle d'or appliquée : on ne supprime jamais une machine ou un compte avant d'avoir copié les preuves (logs Wazuh, captures d'écran).

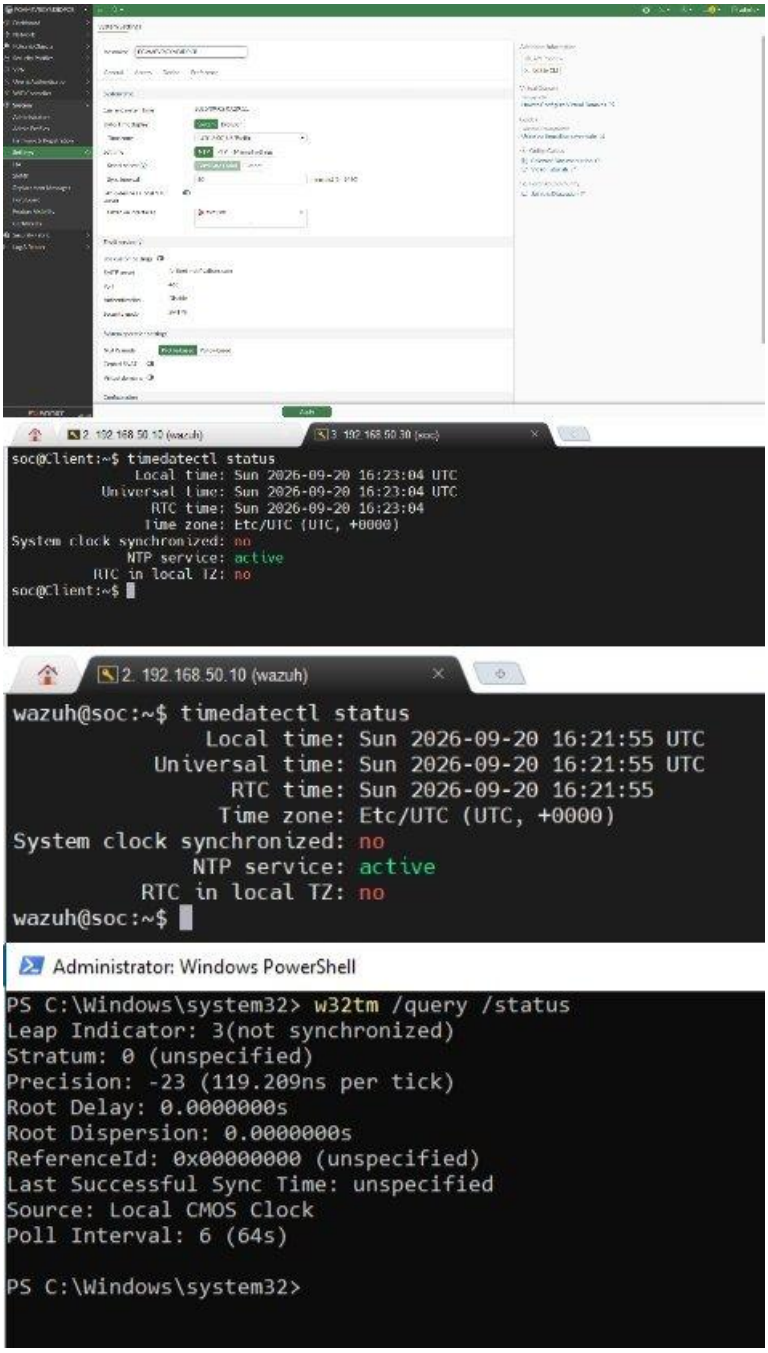
4.1.3 Artefacts produits

- **Manuel des playbooks (livrable D4) :** un guide pratique pour l'analyste de garde, avec un playbook détaillé par incident (Brute Force SSH, scan Nmap, dump LSASS), un lexique simple et un modèle de fiche incident ISO 27035.
- **Rapports d'incidents (livrable L5) :** trois rapports structurés ISO 27035 (INC-2026-001 force brute SSH, INC-2026-002 scan Nmap, INC-2026-003 dump LSASS), avec chronologies, IoC et remédiations.
- **Guide d'installation pas à pas :** procédure complète d'installation de Wazuh (certificats TLS, Indexer, Manager, Dashboard), des agents et de Sysmon.
- **Dépôt Git versionné (exigence ENF-07) :** les configurations du Mini-SOC (ossec.conf du manager, ossec-agent.conf, local_rules.xml, README) sont versionnées dans un dépôt Git local, comme le montre la capture ci-dessous.


2. 192.168.50.30 (soc)
4. 192.168.50.10 (wazuh)
3. /home/mobaxterm
wazuh@soc:~/mini-soc-config$ git log --oneline --graph
* 2c1c0f2 (HEAD -> main) feat: Version initiale des configurations du Mini-SOC (Conforme CDC)
wazuh@soc:~/mini-soc-config$ cd ~/mini-soc-config
git status
On branch main
nothing to commit, working tree clean
wazuh@soc:~/mini-soc-config$ git log --oneline --graph --decorate
* 2c1c0f2 (HEAD -> main) feat: Version initiale des configurations du Mini-SOC (Conforme CDC)
wazuh@soc:~/mini-soc-config$ git ls-tree -r main --name-only
README.md
agent/ossec-agent.conf
manager/ossec.conf
rules/local_rules.xml
wazuh@soc:~/mini-soc-config$ git show --stat
commit 2c1c0f2f5c7882f29f528877067862d728e7f52b (HEAD -> main)
Author: Wazuh Admin <wazuh@soc.local>
Date: Mon Oct 5 17:20:32 2026 +0000
feat: Version initiale des configurations du Mini-SOC (Conforme CDC)
README.md | 28 ++++++
agent/ossec-agent.conf | 0
manager/ossec.conf | 312 ++++++

4.2.2 Synchronisation horaire NTP (ENF-06)

Des horloges synchronisées sont indispensables pour reconstruire une chronologie d'attaque. Le service NTP est activé sur le serveur Wazuh et sur l'Ubuntu Client (timedatectl : « NTP service: active »). Sur le Windows Server, la commande w32tm montre une source « Local CMOS Clock » : la synchronisation externe n'est pas aboutie — c'est un point d'amélioration honnête, détaillé en section 4.3.



Capture d'écran 4.3 : Vérification NTP — timedatectl sur Ubuntu et Wazuh (service NTP actif), w32tm sur Windows (source horloge locale, à corriger).

4.2.3 Matrice de conformité au cahier des charges

Exigence	Contenu	Statut et preuve
EF-01	FortiGate envoie ses logs Syslog au SIEM	Conforme — Syslog UDP 514 vers 192.168.50.10 (capture 2.1)
EF-02	Agent Wazuh + auditd sur Linux	Conforme — agent actif, auditd lu dans ossec.conf (captures 2.2 à 2.4)
EF-03	Sysmon avec profil SwiftOnSecurity sur Windows	Conforme — Sysmon64 running, config v74 (captures 2.5 et 2.6)
EF-04	WEF pour centraliser les Event Logs	Conforme — service Wecsvc actif (capture 2.7)
EF-05 / EF-06	Normalisation JSON et complétude de la collecte	Conforme — documents JSON structurés visibles dans Threat Hunting (capture 2.8)
EF-07 / EF-08	Alertes e-mail (niveau ≥ 10) et Slack (webhook)	Conforme — ossec.conf (capture 3.1), alertes reçues (section 3.3)
EF-09 / EF-10	Niveaux de sévérité et anti-flood	Conforme — échelle 5 niveaux, ignore=300 (section 3.1)
EF-11 à EF-13	Dashboards global, par source, statut agents	Conforme — 4 dashboards (captures 3.2 à 3.6)
EF-14	Export de rapports depuis le dashboard	Partiel — export CSV/« Reporting » disponible dans le dashboard ; rapport PDF automatisé en roadmap
Scénarios	3 scénarios d'attaque simulés et détectés	Dépassé — 7 scénarios détectés (section 3.3)
ENF-01 / ENF-02	Latence < 30 s ; ≥ 500 EPS	Conforme — alertes en quelques secondes, 14 161 événements traités
ENF-03	SIEM accessible 24h/24 en démonstration	Conforme — services activés au démarrage (systemd enabled)
ENF-04	Communications chiffrées TLS 1.2+	Conforme — TLSv1.2 / AES256-GCM vérifié (capture 2.9)
ENF-05	Dashboard protégé par authentification	Conforme — mire de connexion HTTPS (capture 1.3)
ENF-06	Synchronisation NTP (écart < 1 s)	Partiel — NTP actif sur Linux ; Windows à corriger (capture 4.3)
ENF-07 / ENF-08	Configuration versionnée (Git) et documentée	Conforme — dépôt Git + guide d'installation + playbooks
ENF-09	Rapports d'incidents ISO/IEC 27035	Conforme — 3 rapports structurés (INC-2026-001/002/003)

4.3 Obstacles techniques et dépannage

Trois difficultés ont marqué le projet. Les voici, avec la solution adoptée pour chacune.

4.3.1 Obstacle 1 — La NAT du FortiGate masque l'attaquant

Symptôme : dans les alertes Wazuh, l'attaquant Kali (10.10.10.20) apparaît sous l'adresse 192.168.50.1 — l'interface LAN du pare-feu. Au premier abord, on croit que le pare-feu lui-même attaque.

Cause : le FortiGate traduit les adresses (NAT) quand le trafic WAN entre dans le LAN.

Solution : croiser systématiquement les alertes des agents avec les logs du FortiGate pour retrouver la vraie IP source. Cette règle d'analyse a été écrite dans le manuel des playbooks, et un objet de blocage dédié a été créé sur le pare-feu. Piste d'amélioration : utiliser un objet de type « host » (IP unique) plutôt qu'un sous-réseau pour le blocage.

4.3.2 Obstacle 2 — Limites de la licence d'évaluation FortiGate

Symptôme : la VM FortiGate est limitée à 1 vCPU et 2 Go de RAM (97 % de RAM allouée au démarrage), FortiGate Cloud est « Not Supported », et les mises à jour de sécurité (IPS, Antivirus) ne sont pas disponibles.

Cause : la licence d'évaluation FortiGate-VM gratuite bride les ressources et les services.

Solution : réduire les services inutiles sur le pare-feu, surveiller la mémoire via le tableau de bord FortiGate, et concentrer la détection sur le SIEM (qui, lui, dispose de 8 Go de RAM). La journalisation Syslog, elle, fonctionne parfaitement malgré la licence.

4.3.3 Obstacle 3 — Synchronisation NTP et réglage des seuils de détection

Symptôme : le Windows Server indique « not synchronized » (w32tm, source Local CMOS Clock), ce qui fausse les chronologies ; et les premiers tests de la règle R02 généraient trop de petites alertes.

Cause : le service de temps Windows n'était pas pointé vers une source fiable, et la détection du scan journalisait chaque paquet séparément.

Solution : pour le scan, architecture de détection à deux niveaux (règle 100010 informative, puis corrélation 100011 à 10 événements / 60 s) qui transforme le bruit en une seule alerte. Pour le NTP, activation du service sur Linux et Wazuh ; la correction du client temps Windows reste une action ouverte du plan d'amélioration.

4.4 Conclusion et feuille de route

4.4.1 Bilan du projet

Le Mini-SOC est opérationnel et répond au cahier des charges. Concrètement : trois sources de logs (FortiGate, Ubuntu, Windows) sont collectées et normalisées dans Wazuh ; sept règles de détection personnalisées couvrent les cinq catégories exigées (R01 à R05) plus deux scénarios critiques ; les alertes partent en temps réel par e-mail et Slack avec anti-flood ; quatre tableaux de bord supervisent l'ensemble ; et sept attaques simulées ont toutes été détectées et documentées dans des rapports conformes ISO 27035.

4.4.2 Limites actuelles (évaluation honnête)

- Licence d'évaluation FortiGate : ressources limitées (2 Go de RAM), pas de FortiGate Cloud ni de signatures IPS à jour.
- Stockage : le serveur Wazuh dispose de 80 Go ; sans politique de rétention, les index grandiront vite sur une longue période.
- Synchronisation NTP du Windows Server non finalisée (source horloge locale).
- Architecture à nœud unique : pas de haute disponibilité du SIEM.
- Blocage de l'attaquant manuel : la réponse est encore déclenchée par l'analyste.

4.4.3 Feuille de route

- **TheHive + Cortex :** intégrer une plateforme de gestion d'incidents (ticketing) pour tracer chaque alerte, comme proposé en option par le cahier des charges.
- **Wazuh Active Response automatisé :** généraliser le blocage automatique des IP attaquantes (le mécanisme firewall-drop a déjà été observé en test, règle 651) pour passer d'une réaction manuelle à une réaction automatique contrôlée.
- **Détection par Machine Learning :** ajouter des modèles de détection d'anomalies comportementales pour repérer les attaques inconnues, que les règles par signature ne voient pas.
- **Collecte de logs cloud :** étendre la supervision aux services cloud (Office 365, AWS) via les modules Wazuh dédiés.
- **Haute disponibilité et rétention :** cluster Wazuh multi-nœuds et politique d'archivage des index.

En résumé, ce projet démontre qu'avec des outils open-source et une méthode rigoureuse, une petite équipe peut construire un dispositif de détection et de réponse crédible, proche de ce qui existe en entreprise.